

CIS Oracle SaaS Cloud Applications Benchmark

v1.0.0 - 11-14-2025

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is **NEVER** acceptable to host a CIS Benchmark in **ANY** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	5
Important Usage Information	5
Key Stakeholders	5
Apply the Correct Version of a Benchmark	6
Exceptions	6
Remediation	7
Summary	7
Target Technology Details	8
Intended Audience.....	8
Consensus Guidance	9
Typographical Conventions.....	10
Recommendation Definitions.....	11
Title.....	11
Assessment Status.....	11
Automated	11
Manual.....	11
Profile	11
Description.....	11
Rationale Statement	11
Impact Statement.....	12
Audit Procedure.....	12
Remediation Procedure.....	12
Default Value.....	12
References	12
CIS Critical Security Controls® (CIS Controls®).....	12
Additional Information.....	12
Profile Definitions	13
Acknowledgements	14
Recommendations	15
1 Identity and Access Management.....	15
1.1 Ensure Password Policy Enforces Length and Rotation (Manual).....	16
1.2 Ensure MFA is Enforced for All SaaS Users (Manual).....	19
1.3 Ensure Phishing-Resistant MFA Is Enforced for SaaS Administrators and Privileged Accounts (Manual).....	21

1.4 Ensure Fusion Applications Administrators Have Access Only to Fusion Applications Resources (Manual).....	23
1.5 Ensure OCI Console Access Is Restricted to Administrative Accounts (Manual)	25
1.6 Ensure Privileged and Administrative Roles Are Restricted to Known IP Addresses (Manual).....	27
1.7 Ensure Privileged Access is Certified Periodically (Manual)	29
Review users' abilities	29
1.8 Ensure Oracle Break Glass for Fusion Cloud Service Is Enabled (Manual)	31
1.9 Ensure Basic Authentication Is Blocked for SOAP and REST API Integrations (Manual) .	33
1.10 Ensure All API Based Integrations Use OAuth Authentication (Manual).....	35
1.11 Ensure Integration Account Secrets Are Rotated on a Regular Schedule (Manual).....	37
1.12 Ensure EPM Automate Credentials Are Protected via Secure Storage (Manual).....	39
1.13 Ensure Dormant Accounts and Orphaned Identities Are Automatically Detected and Disabled (Manual).....	41
1.14 Ensure Dormant Accounts and Orphaned Identities Are Reviewed and Disabled (Manual)	43
2 Networking	45
2.1 Ensure Network Perimeters are Configured in IAM or the Identity Provider (Manual)	46
2.2 Ensure OCI Console Access Is Restricted to Trusted Networks (Manual)	48
2.3 Ensure Access to Fusion is restricted via Access Control List (ACL) (Manual)	50
2.4 Ensure Location-Based Access Control (LBAC) is enabled (Manual)	52
2.5 Ensure Geolocation Filtering with WAF for SaaS is enforced (Manual).....	54
2.6 Ensure IP-Based Filtering with WAF for SaaS is Enforced (Manual).....	56
2.7 Ensure Qualified Target Filtering with WAF for SaaS is Enforced (Manual)	58
3 Logging and Monitoring	60
3.1 Ensure Fusion Applications Login, Logout and Session Events are Captured, Exported, and Forwarded to Central Logging (Manual)	61
3.2 Ensure EPM Audit Data is Exported and Centrally Stored (Manual)	63
3.3 Ensure to enable Audit on BI Publisher and OTBI Activity (Execution, Modification, and Usage Analytics) (Manual).....	65
3.4 Ensure BPM Approval Rule and Workflow Configuration Changes Are Audited (Manual) 68	
3.5 Ensure Logging Pipelines are Monitored for Failures to Prevent Silent Loss of Audit Events (Manual).....	70
4 Application Configuration Management	72
4.1 Security Configuration Changes	73
4.1.1 Ensure Changes to Audit Policy Settings Are Monitored (Manual)	74
4.1.2 Ensure Configuration Changes to HCM Security Profile Setups Are Monitored (Manual)	77
4.1.3 Ensure Unused Custom Roles Are Disabled or Monitored (Manual)	79
4.2 High Risk Business Transactions & User Actions	81
4.2.1 Ensure Changes to Payment Setups Are Monitored (Manual)	82
4.2.2 Ensure Unused Business Setups Are Disabled (Manual)	84
4.3 Ensure Configuration Changes to Roles Built for IT Superusers Are Monitored (Manual) 86	
4.4 Ensure Uploaded Files Are Scanned for Viruses and Restricted by Extension Policy (Manual).....	88
5 Application Access Control	90
5.1 IT Administrator Separation of Duties (SoD)	91
5.1.1 Ensure Transactions Created/Updated by Fusion Administrators Are Monitored (Manual)	92
5.1.2 Ensure Assignments of Substantial Access to Fusion Users Are Monitored (Manual) ...	94
5.1.3 Ensure Assignments of Substantial Access to EPM Administrators Are Monitored (Manual).....	96
5.2 Application Superuser Separation of Duties (SoD).....	98

5.2.1 Ensure Assignments of Substantial Access to Business Users Are Monitored (Manual)	99
5.3 Application Business User Separation of Duties (SoD)	101
5.3.1 Ensure SoD Within Fusion Is Monitored (Manual)	102
5.3.2 Ensure SoD Across Fusion and EPM Is Monitored (Manual)	104
5.3.3 Ensure SoD Across Fusion and OCI Is Monitored (Manual)	106
5.3.4 Ensure Fusion ERP Transactions Allowed by SoD Violations Are Monitored (Manual)	108
5.3.5 Ensure Fusion HCM Transactions Allowed by SoD Violations Are Monitored (Manual)	110
5.3.6 Ensure Shared EPM Accounts Are Monitored (Manual)	112
5.3.7 Ensure Potential Ghost Employees Are Monitored (Manual)	114
Appendix: Summary Table	116
Appendix: CIS Controls v8 IG 1 Mapped Recommendations	120
Appendix: CIS Controls v8 IG 2 Mapped Recommendations	122
Appendix: CIS Controls v8 IG 3 Mapped Recommendations	125
Appendix: CIS Controls v8 Unmapped Recommendations	128
Appendix: Change History	129

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the [CIS Website](#). They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- [CIS Configuration Assessment Tool \(CIS-CAT® Pro Assessor\)](#)
- [CIS Benchmarks™ Certified 3rd Party Tooling](#)

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that **ALL** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.
- **Use the most recent version of a Benchmark:** This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed [Build Kits](#) for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
 - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
 - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
 - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
 - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
 - When the initial deployment above is completed successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the [CIS Website](#). All other formats of the CIS Benchmarks™ (MS Word, Excel, and [Build Kits](#)) are available for CIS [SecureSuite](#)® members.

CIS-CAT® Pro is also available to CIS [SecureSuite](#)® members.

Target Technology Details

This document, CIS (Center for Internet Security) Oracle SaaS Foundations benchmark, provides prescriptive guidance for establishing a secure baseline configuration for Oracle SaaS environments. The scope of this benchmark is to establish a base level of security for organizations utilizing the included Oracle SaaS applications. The benchmark is not an exhaustive list of all possible security configurations and architectures. The benchmark should be taken as a starting point and tailored as appropriate to meet site-specific needs.

This benchmark covers Oracle Fusion and EPM SaaS Applications where explicitly highlighted, and will be extended to other Oracle SaaS applications in future releases.

Additionally, Oracle SaaS applications are associated with an Oracle Cloud Infrastructure tenancy. Therefore, organizations should also leverage the Oracle Cloud Infrastructure Foundations Benchmark to establish a secure baseline configuration for their OCI tenancy running Oracle SaaS.

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk staff, platform deployment teams, and DevOps personnel who plan to develop, deploy, assess, or secure solutions within Oracle SaaS environments.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
<code><Monospace font in brackets></code>	Text set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like Notes , Warnings , or Cautions (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

Items in this profile are intend to:

- be practical and prudent;
- provide security focused best practice hardening of a technology; and
- limit impact to the utility of the technology beyond acceptable means.

- **Level 2**

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is more critical than manageability and usability
- acts as defense in depth measure
- may impact the utility or performance of the technology
- may include additional licensing, cost, or addition of third party software

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Author

Josh Hammer
Barry Greenhut
Roland Koenn

Contributor

Mike Wicks
Ranveer Tiwari

Recommendations

1 Identity and Access Management

This section contains recommendations for configuring identity and access management related options. These controls help ensure that user identities, roles, and permissions are managed securely to reduce the risk of unauthorized access and to support compliance requirements.

1.1 Ensure Password Policy Enforces Length and Rotation (Manual)

Profile Applicability:

- Level 1

Description:

A strong password policy helps protect Oracle Fusion and EPM SaaS environments against unauthorized access by enforcing minimum standards for password length, rotation, and reuse prevention for both user and administrative accounts.

Administrators can configure password policies in:

- Fusion SaaS (pre-upgrade environments): **Security Console Administration Password Policy**
- Fusion SaaS (upgraded environments) and Oracle EPM: OCI IAM Identity Domain Console

Recommended Configuration:

- Require passwords to be at least 14 characters in length.
- Prevent reuse of the last five passwords.
- Require administrative passwords to expire and be changed at least every 365 days.
- Lock accounts after five failed login attempts.

These parameters are available and enforceable in both pre-upgrade and post-upgrade identity configurations across Oracle Fusion and EPM SaaS applications.

Rationale:

Enforcing password length and rotation reduces the likelihood that weak or compromised passwords are exploited to gain unauthorized access.

Overly frequent password changes can lead to insecure workarounds such as predictable patterns or insecure storage. Use of longer password utilizing passphrases should be encouraged to make passwords easier for users to remember. Balance password policy strictness with usability, and complement with multi-factor authentication (MFA) to minimize reliance on passwords alone.

Audit:

For pre-upgrade environments:

1. Sign in as a Security Administrator or IT Security Manager.
2. Navigate to **Tools, Security Console, Administration, Password Policy**.

3. Verify that:

- Minimum length is ≥ 14 characters.
- Password expiration is ≤ 365 days.
- Password reuse prevention is ≥ 5 previous passwords.
- Account lockout triggers after ≤ 5 failed login attempts.

For EPM and post-upgrade environments (OCI IAM Identity Domain):

1. In the OCI Console, go to **Identity & Security, Domains, Security, Password Policy**.
2. Confirm the equivalent settings:
 - Minimum length ≥ 14 .
 - Expiration ≤ 365 days.
 - Password history ≥ 5 .
 - Account lockout ≤ 5 failed attempts.
3. Ensure lockout duration and auto-unlock timing meet organizational requirements.

Remediation:

Pre-upgrade (Security Console):

1. Navigate to Navigator **Tools, Security Console, Administration, Password Policy**.
2. Configure the following values:
 - Minimum Length: 14
 - Require Numbers: No
 - Require Special Characters: No
 - Password Expiration (Days): 365
 - Prevent Reuse of Last Passwords: 5
 - Failed Sign-In Attempts Before Lockout: 5
3. Save and communicate changes to all users.

EPM & Post-upgrade (OCI IAM Identity Domain):

1. In the OCI Console, open the Identity Domain **Security, Password Policy**.
2. Configure equivalent parameters for length, complexity, expiration, reuse prevention, and lockout.
3. Save policy updates; they take immediate effect for all users.

References:

1. <https://docs.oracle.com/en/cloud/saas/human-resources/ochus/password-policy.html>
2. https://docs.oracle.com/en/cloud/saas/enterprise-performance-management-common/cgsad/setting_password_policies.html
3. <https://docs.oracle.com/en-us/iaas/Content/Identity/passwordpolicies/Managing-Password-Policies.htm>

Additional Information:

By default, Fusion Applications enforce a minimum of 8 characters without rotation or reuse prevention. Password complexity, expiration, and history are not enabled by default and must be explicitly configured.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			

1.2 Ensure MFA is Enforced for All SaaS Users (Manual)

Profile Applicability:

- Level 1

Description:

Multi-Factor Authentication (MFA) requires users to present an additional verification factor beyond username and password. In Oracle Fusion environments, native MFA enforcement via Identity Domain sign-on policies functions only after the environment's identity service is upgraded to OCI IAM. For environments not yet upgraded, MFA must remain delegated to an external IdP or await the identity upgrade. Where supported, phishing-resistant factors (for example, FIDO2/WebAuthn passkeys or hardware security keys) are preferred over SMS or email OTP.

Rationale:

MFA protects against credential theft and password reuse attacks. Enforcing MFA across all SaaS users - whether they authenticate through the Fusion Identity Domain, an external OCI IAM domain, or another IdP—provides consistent protection and centralized policy control.

Impact:

After enabling native MFA, some SaaS users may face login friction or need guidance to enroll. Legacy integrations or non-interactive accounts may require updates. Before the identity upgrade, users must rely on IdP enforcement or delay MFA enforcement in the environment itself.

Audit:

1. Check if the Fusion environment is upgraded to OCI IAM or uses an external IdP.
2. If on OCI IAM, review **Security Console, User Categories, Two-Factor Authentication** and confirm all user categories have MFA enabled.
3. If identity upgrade is not yet performed, verify that MFA is enforced via the external IdP for all users.
4. Test login with a standard SaaS user account and confirm MFA is required (native or via IdP).

Remediation:

1. If the Fusion environment is upgraded to OCI IAM:
 - In Fusion Security Console **User Categories, Two-Factor Authentication**, enable MFA for all categories.
2. If the environment is not upgraded or uses a federated IdP:

- Enable MFA in the external IdP or external OCI IAM domain and ensure it applies to all users accessing Fusion.
3. Communicate enrollment instructions and verify MFA enrollment via Fusion **My Profile, Manage Secure Verification**.
 4. Perform test logins to confirm MFA prompts are consistently applied.

Default Value:

Native MFA for all SaaS users is not available before identity upgrade. Once the environment is on OCI IAM, MFA is not enabled by default for all SaaS users.

References:

1. <https://docs.oracle.com/en/cloud/saas/applications-common/25d/faser/enable-multifactor-authentication.html>
2. <https://docs.oracle.com/en-us/iaas/Content/Identity/Tasks/usingmfa.htm>
3. <https://www.ateam-oracle.com/post/securing-oracle-fusion-cloud-supplier-portal-with-iam-domains-and-mfa>

Additional Information:

The Identity Upgrade is currently in flight - all details can be found here: <https://docs.oracle.com/en-us/iaas/Content/fusion-applications/identity-migration-overview.htm>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 <u>Require MFA for Externally-Exposed Applications</u> Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.		●	●
v8	6.5 <u>Require MFA for Administrative Access</u> Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.	●	●	●

1.3 Ensure Phishing-Resistant MFA Is Enforced for SaaS Administrators and Privileged Accounts (Manual)

Profile Applicability:

- Level 1

Description:

Multi-Factor Authentication (MFA) requires users to present an additional verification factor beyond username and password. In Oracle Fusion environments, native MFA enforcement via Identity Domain sign-on policies functions only after the environment's identity service is upgraded to OCI IAM or an external IdP. For environments not yet upgraded, MFA must be delegated to an external IdP or await the identity upgrade. SaaS Administrators and other SaaS privileged accounts must authenticate using phishing-resistant MFA methods such as FIDO2/WebAuthn security keys, platform passkeys, or passwordless authentication. Weaker factors such as SMS OTP or email OTP should be disabled for administrative and privileged accounts.

Rationale:

Privileged accounts are high-value targets. Enforcing MFA with phishing resistant factors reduces the risk of unauthorized administrative access even if credentials are compromised. To use native MFA, the identity service must be on OCI IAM, which provides the required support for enforcing sign-on policies and MFA natively.

Impact:

Enabling native MFA with phishing resistant post-upgrade may cause disruption if SaaS users do not enroll or if legacy integrations require reconfiguration. Until the identity upgrade is complete, SaaS administrators must rely on IdP-based MFA or delay enforcement.

Audit:

1. Determine if the Fusion environment has been upgraded to use OCI IAM (check Fusion environment's maintenance/upgrade status) or is using an external IdP for MFA.
2. Access the Security Console **User Categories Two-Factor Authentication** and confirm SaaS administrators/privileged categories have MFA enabled. Only enable factors that are considered phishing resistant.
3. If identity upgrade has not occurred, verify that MFA is enforced via the external IdP for privileged accounts.
4. Test login with a privileged account and confirm MFA prompt is required (native or via IdP).

Remediation:

1. If identity upgrade is not finalized implement MFA via the external IdP.
2. After the upgrade, in the Security Console open **User Categories Two-Factor Authentication** and enable MFA for administrator/privileged categories.
3. Define valid phishing resistant MFA factors (mobile authenticator, FIDO, etc.).
4. Save settings and ensure SaaS users enroll in MFA during their next login.
5. Test that privileged accounts require MFA (OCI IAM) and fallback to IdP enrollment where needed.

Default Value:

Before identity upgrade, native MFA enforcement in Identity Domains is unavailable. After upgrade, MFA is not enforced by default.

References:

1. docs.oracle.com/en/cloud/saas/applications-common/25c/oacpr/set-up-multifactor-authentication-methods.html
2. <https://docs.oracle.com/en-us/iaas/Content/Identity/Tasks/usingmfa.htm>

Additional Information:

The Identity Upgrade is currently in flight - all details can be found here: <https://docs.oracle.com/en-us/iaas/Content/fusion-applications/identity-migration-overview.htm>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.			

1.4 Ensure Fusion Applications Administrators Have Access Only to Fusion Applications Resources (Manual)

Profile Applicability:

- Level 2

Description:

Ensure that Fusion Applications Administrators are granted Console access only to Fusion Applications resources. Their IAM policies must be scoped exclusively to the fusion-applications-family resource type, without granting access to other OCI services.

Rationale:

Fusion Applications Administrators are responsible for managing SaaS environments, not the broader OCI infrastructure. Granting them access to additional OCI services (for example, Compute, Networking, Object Storage) is unnecessary and increases the attack surface. Restricting their access to Fusion Applications resources enforces least privilege, reduces risk of accidental or malicious changes to unrelated services, and aligns with compliance requirements for segregation of duties.

Impact:

Fusion Applications Administrators will not be able to manage or view non-Fusion OCI services in the Console. Separate administrative groups must be established for infrastructure or cross-service management. Organizations must ensure that Fusion-only administrators are properly segregated from broader OCI admin groups.

Audit:

1. Navigate to **Identity & Security Policies**.
2. Review policies attached to groups containing Fusion Applications Administrators.
3. Confirm that:
 - Policies use the fusion-applications-family resource type.
 - No broad tenancy-wide permissions (such as manage all-resources or unrelated service resource types) are present.
4. Verify that Console access for Fusion Administrators shows only Fusion Applications in the navigation menu.

Remediation:

1. Identify the group(s) used for Fusion Applications Administrators (e.g., FusionAdmins).
2. Remove any existing policies that provide access to non-Fusion OCI services.

3. Create or update the policy to restrict privileges to Fusion Applications only:

- For administrators:

Allow group FusionAdmins to manage fusion-applications-family in tenancy

- For read-only roles (if needed):

Allow group FusionViewers to read fusion-applications-family in tenancy

Default Value:

By default, users have no access to Fusion Applications or other OCI services until policies are explicitly created. Without careful scoping, administrators could inadvertently be granted broad tenancy permissions (for example, manage all-resources), giving them access beyond Fusion Applications.

References:

1. <https://docs.oracle.com/en-us/iaas/Content/fusion-applications/managing-access.htm#iam-resource-type>
2. <https://docs.oracle.com/en-us/iaas/Content/Identity/Concepts/policyoverview.htm>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v8	6.7 Centralize Access Control Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.			

1.5 Ensure OCI Console Access Is Restricted to Administrative Accounts (Manual)

Profile Applicability:

- Level 1

Description:

Ensure that only designated administrative accounts are allowed to log in to the Oracle Cloud Infrastructure (OCI) Console. All non-admin user accounts must have the console password capability disabled, and sign-on policies must restrict Console application access to administrative groups only.

Rationale:

The OCI Console provides broad administrative access. Restricting console login exclusively to administrative accounts minimizes the risk of unauthorized changes and reduces the attack surface in case of credential compromise. Non-administrative users can still interact with OCI through APIs, SDKs, or federated identity providers without requiring console access.

Impact:

Users without console access must rely on alternate methods (API, SDK, CLI, or federated IdP). Organizations must maintain a secure break-glass account to avoid lockouts.

Audit:

1. Navigate to **Identity & Security Domains Users**.
 - For each non-admin user, confirm that Can use Console password is unchecked under Edit User Capabilities.
2. Navigate to **Domains Security Sign-On Policies**.
 - Verify there is a policy rule that allows Console access only for designated administrative groups.
 - Confirm that a deny rule is in place for all other users.

Remediation:

1. For each non-admin user:
 - Navigate to **Identity & Security Domains Edit User Capabilities**.
 - Uncheck Can use Console password.
 - Save changes.

2. Update the Sign-On Policy for the identity domain:
 - Add a rule that allows Console login only for users in an Admin group.
 - Add a default deny rule for all other users.
3. Test the configuration by attempting Console login with both an admin and a non-admin account.

Default Value:

By default, every newly created user in an OCI Identity Domain can log in to the OCI Console (because the Can use Console password capability is enabled by default).

References:

1. <https://docs.oracle.com/en-us/iaas/Content/Identity/users/edit-users-capabilities.htm>
2. <https://docs.oracle.com/en/learn/access-to-oci-console/index.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 <u>Restrict Administrator Privileges to Dedicated Administrator Accounts</u> Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v8	5.6 <u>Centralize Account Management</u> Centralize account management through a directory or identity service.			

1.6 Ensure Privileged and Administrative Roles Are Restricted to Known IP Addresses (Manual)

Profile Applicability:

- Level 1

Description:

When Location-Based Access Control (LBAC) is enabled in Oracle Fusion Applications, administrative and privileged roles must not be configured for unrestricted access. In the Fusion Security Console, privileged roles such as IT Security Manager and Application Implementation Consultant include the option “Enable Role for Access from All IP Addresses.” This setting should remain disabled, ensuring these roles can only be accessed from known and approved IP ranges defined within the LBAC configuration or associated network perimeter.

Rationale:

Restricting administrative and privileged access to known IP ranges prevents unauthorized or high-risk logins from untrusted networks. This measure reduces the attack surface for high-privilege accounts and aligns with the principle of least privilege by ensuring elevated functions are only available from managed corporate networks or approved secure endpoints.

Impact:

Enforcing IP restrictions may require administrators to connect through approved corporate networks, VPNs, or bastion environments. Improperly configured IP ranges could temporarily block administrative access until corrected, so changes should be planned and verified in advance.

Audit:

1. Confirm that LBAC is enabled for the Fusion environment.
2. Sign in to Fusion Security Console with appropriate privileges.
3. Navigate to **Roles, Search, IT Security Manager** (and other privileged roles).
4. Open the role and go to the **Administration tab**.
5. Verify that the checkbox **Enable Role for Access from All IP Addresses** is not selected.
6. Confirm that privileged roles are associated with the intended network perimeter or known IP range within LBAC configuration.

Remediation:

1. Sign in to Fusion Security Console with an administrative account.
2. Navigate to **Roles, Search, IT Security Manager** (or equivalent privileged roles).

3. Go to the **Administration** tab and ensure the checkbox **Enable Role for Access from All IP Addresses** is cleared.
4. Verify that the role is correctly assigned to the appropriate network perimeter under LBAC settings, restricting access to known IP ranges.
5. Test access from a trusted IP and confirm the role remains functional; test from an unapproved IP to confirm access is denied.

Default Value:

When LBAC is enabled, privileged and administrative roles are not accessible from all IP addresses by default. They must be explicitly granted such access through the “Enable Role for Access from All IP Addresses” option.

References:

1. <https://docs.oracle.com/en/cloud/saas/human-resources/ochus/overview-of-location-based-access.html>
2. <https://docs.oracle.com/en/cloud/saas/human-resources/ochus/enable-and-disable-location-based-access.html>
3. <https://docs.oracle.com/en/cloud/saas/applications-common/25d/oasec/manage-roles.html>
4. <https://docs.oracle.com/en/cloud/saas/human-resources/ochus/how-can-i-make-a-role-public.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			

1.7 Ensure Privileged Access is Certified Periodically (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that only authorized users retain elevated access, by reviewing users' abilities periodically - monthly for IT administrators and quarterly for others.

Rationale:

Users could accumulate roles and data access as their responsibilities change, giving them elevated or unintended abilities that they could use erroneously or maliciously with substantial impact on operations and finances.

Impact:

If users are allowed to retain those abilities, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Review users' abilities

Manual method:

1. Navigate to **Tools Scheduled Processes**
2. Review **User and Role Access Audit Report** and **User Role Membership Report** (or schedule them, then review them).

Automated method:

1. Initiate one or more Access Certification campaigns in Fusion Cloud Applications Risk Management using the instructions in [Digitize Access Certification Workflows](#).
2. For example, initiate campaigns to review users with unauthorized access; detect privilege creep (accumulation of access no longer required); or detect users, organizations or roles recently added or not included in the reviews.

Remediation:

When a role should be removed from a user either:

- Remove unwanted role.

- Leave role and monitor the transactions performed by the user (see below).
1. Review the user's actions since the previous review:

Manual method:

1. Navigate to **Tools Reports and Analytics**.
2. Select the appropriate dashboards or reports.
3. Review the transactions that the role allows.

Automated method: 1.Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs.

1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

No periodic review enforced by default.

References:

1. <https://community.oracle.com/customerconnect/discussion/551382/digitize-access-certification-workflows>
2. <https://community.oracle.com/customerconnect/discussion/579152/continuously-monitor-transactions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.2 Establish an Access Revoking Process Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.			

1.8 Ensure Oracle Break Glass for Fusion Cloud Service Is Enabled (Manual)

Profile Applicability:

- Level 2

Description:

Oracle Break Glass for Fusion Cloud Service provides a customer-controlled workflow that governs Oracle personnel's emergency access to the Fusion Cloud database and middleware tiers. When enabled, Oracle cannot access customer data without explicit approval from your designated administrators for each one-off service activity.

Rationale:

Activating and monitoring the Break Glass service ensures that privileged Oracle support access occurs only under strict governance, audit logging, and time-bound approvals, reducing insider and third-party access risk.

Impact:

Minimal operational impact and a one time fee. Requires process awareness among administrators to review and approve Oracle access requests promptly when raised.

Audit:

In console:

1. Go to: Access Oracle Cloud Console
2. Select **My Services** → **Subscriptions** → **Fusion Cloud Service**
3. Verify that Break Glass status is **Enabled**
4. Verify that designated approvers are defined in the workflow
5. Verify that post-access revocation and audit logs are retained

Remediation:

In console:

1. Activate Break Glass service via Oracle Cloud Subscription management.
2. Define approvers (Fusion Cloud Administrators).
3. Enable notifications for Break Glass request/approval activities.
4. Enable post-access revocation and audit logs are retained

Default Value:

Disabled by default; must be explicitly requested and activated through Oracle Support or Cloud Account Manager.

References:

1. Oracle Break Glass for Fusion Cloud Service - <https://docs.oracle.com/en/cloud/get-started/subscriptions-cloud/mmocs/oracle-break-glass-fusion-cloud-service.html>
2. <https://www.oracle.com/latam/a/ocom/docs/corporate/pricing/oracle-fusion-cloud-global-price-list.pdf>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.2 <u>Establish an Access Revoking Process</u> Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.			
v8	6.7 <u>Centralize Access Control</u> Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.			

1.9 Ensure Basic Authentication Is Blocked for SOAP and REST API Integrations (Manual)

Profile Applicability:

- Level 2

Description:

Organizations must block the use of Basic Authentication for all SOAP and REST API integrations with Oracle SaaS Applications. This can be achieved by disabling Basic Authentication at the Fusion Applications layer and enforcing OAuth 2.0 as the only supported authentication method. Automated monitoring of Fusion audit logs and OCI IAM authentication logs should also be configured to detect and alert on attempted Basic Authentication use.

Rationale:

Blocking Basic Authentication prevents insecure clients from connecting, even if misconfigured. Combined with monitoring, this ensures that only OAuth tokens are accepted, reducing exposure to replay attacks, credential theft, and non-compliant integrations.

Impact:

Blocking Basic Authentication may cause disruptions for legacy integrations that have not yet been migrated. Organizations must ensure migration to OAuth is complete before disabling Basic Authentication globally.

Audit:

1. Review your Service Request history with Oracle to confirm a request has been submitted to disable Basic Auth for APIs.
2. Confirm Oracle's response/documentation showing that Basic Auth is disabled in the environment.
3. Attempt API calls using Basic Authentication and verify they fail.
4. Use supported authentication (JWT, SAML, OAuth) to confirm the API works with secure methods.

Remediation:

1. Submit a Service Request to Oracle SaaS Operations asking to disable Basic Authentication for APIs in your Fusion instance.
2. Include details of your current integrations (endpoints, methods) that rely on Basic Auth.
3. Confirm with Oracle that Basic Auth has been disabled in your environment.
4. Update all integrations to use supported methods (JWT, OAuth, SAML) per Oracle guidance.

5. Test all APIs to validate they function correctly under the new authentication method.

Default Value:

Fusion Applications and OCI IAM domains do not block Basic Authentication by default. Customers must configure this explicitly.

References:

1. <https://blogs.oracle.com/cloud-infrastructure/post/secure-api-access-in-oracle-fusion-applications>
2. <https://blogs.oracle.com/ateam/post/implement-jwt-token-authentication-with-fusion-cloud-application-restsoap-extend-in-nodejs-based-applications>
3. <https://docs.oracle.com/en/cloud/saas/applications-common/25d/oaext/configure-oauth.html>
4. <https://www.ateam-oracle.com/post/enabling-oauth-20-jwt-authentication-for-oracle-soap-services-in-oic-gen3>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	16.11 <u>Leverage Vetted Modules or Services for Application Security Components</u> Leverage vetted modules or services for application security components, such as identity management, encryption, and auditing and logging. Using platform features in critical security functions will reduce developers' workload and minimize the likelihood of design or implementation errors. Modern operating systems provide effective mechanisms for identification, authentication, and authorization and make those mechanisms available to applications. Use only standardized, currently accepted, and extensively reviewed encryption algorithms. Operating systems also provide mechanisms to create and maintain secure audit logs.			

1.10 Ensure All API Based Integrations Use OAuth Authentication (Manual)

Profile Applicability:

- Level 1

Description:

All API based integrations with Oracle SaaS Applications must use OAuth 2.0 authentication configured through the Fusion Identity Domain. Basic Authentication, long-lived static passwords, or legacy authentication mechanisms must not be used for API or integration access. OAuth provides secure, token-based authentication with support for scopes, expiration, and revocation.

Rationale:

Basic Authentication and static credentials present significant risks, including credential theft, replay attacks, and the inability to enforce least-privilege access. Modern integrations require stronger controls to protect sensitive business transactions and data. Enforcing OAuth for all API and integration access aligns with industry standards and provides stronger security controls, including token expiration, scoped access, and easier revocation.

Impact:

Migrating legacy SOAP or REST integrations from Basic Authentication to OAuth may require reconfiguration and development effort. This transition ensures greater security and long-term supportability.

Audit:

1. Review all configured SOAP and REST integrations in Fusion Applications and Oracle Integration Cloud.
2. Confirm that integration clients are registered as OAuth clients in the Fusion Identity Domain and that Basic Authentication credentials are not in use.
3. Examine Fusion audit logs to identify API requests authenticated with Basic Authentication.
4. Review OCI IAM Identity Domain authentication logs to confirm that API access tokens are issued via OAuth flows only.
5. Validate that no unscoped or legacy credentials are present in active integrations.

Remediation:

1. Identify integrations currently using Basic Authentication by reviewing Fusion audit logs and OCI IAM authentication records.

2. Register OAuth clients in the Fusion Identity Domain for each integration, assigning only the required scopes and authorized resources.
3. Reconfigure integrations to use OAuth tokens in place of Basic Authentication credentials.
4. Disable or revoke Basic Authentication credentials in Fusion Applications and IAM domains.
5. Establish a recurring process to review Fusion and IAM logs to detect any attempted Basic Authentication use.

Default Value:

By default, Fusion Applications support OAuth but do not block the use of Basic Authentication unless it is explicitly disabled. Customers must enforce OAuth for all API access.

References:

1. <https://docs.oracle.com/en/cloud/saas/applications-common/25d/oaext/configure-oauth.html>
2. <https://blogs.oracle.com/cloud-infrastructure/post/secure-api-access-in-oracle-fusion-applications>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	16.11 <u>Leverage Vetted Modules or Services for Application Security Components</u> Leverage vetted modules or services for application security components, such as identity management, encryption, and auditing and logging. Using platform features in critical security functions will reduce developers' workload and minimize the likelihood of design or implementation errors. Modern operating systems provide effective mechanisms for identification, authentication, and authorization and make those mechanisms available to applications. Use only standardized, currently accepted, and extensively reviewed encryption algorithms. Operating systems also provide mechanisms to create and maintain secure audit logs.			

1.11 Ensure Integration Account Secrets Are Rotated on a Regular Schedule (Manual)

Profile Applicability:

- Level 1

Description:

Oracle SaaS environments often integrate with external systems using service accounts, OAuth clients, JWT signing keys, and X.509 certificates. These credentials are typically long-lived and, if not rotated regularly, may be compromised or reused by unauthorized parties. Organizations should enforce a policy to rotate all integration account secrets on a defined schedule, for example every 90 or 180 days, and update dependent integrations accordingly.

Rationale:

Long-lived credentials represent a significant risk if stolen, exposed in logs, or left unmanaged. Regular rotation reduces the risk window for credential misuse and aligns with best practices for key management. Scheduled rotation ensures that even if a secret is compromised, it cannot be abused indefinitely.

Impact:

Rotating integration secrets requires careful planning and coordination, as dependent applications and partners must update their configurations. Failure to update all endpoints may result in temporary service disruptions. Organizations must balance operational overhead with security benefits.

Audit:

1. Review integration accounts in Oracle Fusion Applications and identify all OAuth clients, JWT keys, and certificates in use.
2. Confirm that each credential has a documented rotation policy, including expiration and renewal dates.
3. Validate logs or change records to confirm that credentials have been rotated within the organization's defined schedule (for example, within the past 180 days).
4. Check for expired or inactive credentials and confirm they are removed from production environments.

Remediation:

1. Develop an inventory of all integration account secrets, including OAuth credentials, JWT keys, and certificates.
2. Define a rotation schedule (for example, 90 or 180 days) aligned with organizational policy and compliance requirements.

3. Rotate each credential according to the schedule, updating dependent integrations and notifying stakeholders.
4. Remove or revoke any unused or expired credentials to reduce the attack surface.
5. Document the process and maintain records of all credential rotations for audit purposes.

Default Value:

By default, Fusion Applications and related SaaS services do not enforce automatic expiration or rotation of integration account secrets. Credential rotation must be managed by the customer.

References:

1. <https://docs.oracle.com/en/cloud/saas/applications-common/25c/oaext/configure-oauth.html>
2. <https://docs.oracle.com/en/cloud/saas/applications-common/25d/faser/overview-of-certificates.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.1 Establish and Maintain a Secure Configuration Process Establish and maintain a secure configuration process for enterprise assets (end-user devices, including portable and mobile, non-computing/IoT devices, and servers) and software (operating systems and applications). Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.			
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			

1.12 Ensure EPM Automate Credentials Are Protected via Secure Storage (Manual)

Profile Applicability:

- Level 1

Description:

EPM Automate requires credentials to execute commands such as data load, snapshot management, or audit log export. These credentials must never be stored in plaintext within scripts or configuration files. Instead, credentials must be secured using Oracle's encrypted password file (created with the encrypt command) or by integrating with secure enterprise credential vaults and OS-level key stores.

Rationale:

Storing credentials in plaintext exposes privileged accounts to theft and misuse. EPM Automate is commonly executed with Service Administrator-level rights, making it a high-value target. Using the encrypted password file or secure storage mechanisms significantly reduces the risk of credential exposure and aligns with security best practices.

Impact:

Adopting encrypted storage introduces operational overhead (managing encrypted files, updating scripts, rotating credentials). However, the risks of not securing credentials - including unauthorized access, privilege escalation, and data breaches — far outweigh the effort required.

Audit:

1. Review all automation scripts, scheduled jobs, and CI/CD processes invoking EPM Automate.
2. Verify that credentials are not stored in cleartext (e.g. in batch files, shell scripts, or parameters).
3. Confirm that either:
 - The Oracle encrypted password file is being used, or
 - Credentials are retrieved securely from an OS-level key store (e.g. Windows Credential Manager, Linux keyring) or an enterprise vault (e.g. CyberArk, HashiCorp Vault, OCI Vault).
4. Validate that credential rotation is in place and documented.

Remediation:

- Use the EPM Automate encrypt command to generate an encrypted password file and update scripts to reference it instead of plaintext arguments.
- Alternatively, configure integration with an enterprise password vault or OS secure key store to inject credentials at runtime.
- Regularly rotate credentials and regenerate encrypted storage files.
- Audit existing automation jobs to ensure compliance and remove any residual plaintext credentials.

Default Value:

By default, EPM Automate accepts credentials as plaintext arguments if no secure method is configured. Secure storage must be explicitly implemented.

References:

1. https://docs.oracle.com/en/cloud/saas/enterprise-performance-management-common/cgsad/3_info_security_secure_cred_storage.html
2. https://docs.oracle.com/en/cloud/saas/enterprise-performance-management-common/cgsad/3_info_security_epm_cloud_pword.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.5 <u>Establish and Maintain an Inventory of Service Accounts</u> Establish and maintain an inventory of service accounts. The inventory, at a minimum, must contain department owner, review date, and purpose. Perform service account reviews to validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.			

1.13 Ensure Dormant Accounts and Orphaned Identities Are Automatically Detected and Disabled (Manual)

Profile Applicability:

- Level 2

Description:

Dormant accounts and orphaned identities should be detected and disabled using automated identity governance capabilities. Policies should be configured in OCI Identity Domains or integrated identity governance platforms to automatically flag and disable accounts that have not logged in within a defined period, or that have no role assignments or ownership.

Rationale:

Automated detection and disabling reduces reliance on manual reviews, minimizes human error, and ensures consistent enforcement. This strengthens the organization's security posture and reduces the window of opportunity for account misuse.

Impact:

Automation requires integration with identity governance tooling and careful configuration to avoid unintended lockouts. Exceptions may need to be defined for service or integration accounts.

Audit:

1. Verify that identity governance policies are configured to automatically detect dormant and orphaned accounts.
2. Review policy logs to confirm detection and disabling actions have occurred.
3. Check for exceptions or exclusions and validate that they are documented and approved.

Remediation:

1. Implement identity governance tooling in OCI Identity Domains or an integrated IAM solution.
2. Configure policies to flag accounts inactive for more than 90 days or lacking ownership/role assignments.
3. Set policies to disable such accounts automatically while notifying administrators.
4. Define exceptions for service accounts and apply compensating monitoring controls.
5. Periodically review policy effectiveness and adjust thresholds as needed.

Default Value:

By default, automatic disabling of dormant and orphaned accounts is not enforced in Oracle SaaS.

References:

1. <https://docs.oracle.com/en/cloud/saas/human-resources/ochus/manage-hcm-user-accounts.html>
2. <https://docs.oracle.com/en-us/iaas/Content/identity/domains/managing.htm>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 Disable Dormant Accounts Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			

1.14 Ensure Dormant Accounts and Orphaned Identities Are Reviewed and Disabled (Manual)

Profile Applicability:

- Level 1

Description:

Dormant accounts and orphaned identities should be identified and disabled on a regular schedule. Dormant accounts are active accounts that have not been used for a defined period, such as 90 days. Orphaned identities are accounts with no associated owner or role assignment. Manual reviews of account activity in Fusion Applications and OCI Identity Domains should be conducted at least quarterly to detect such accounts.

Rationale:

Inactive or orphaned accounts present unnecessary risk, as they may still be accessible but not actively monitored. Regular reviews reduce the chance that attackers exploit forgotten accounts to gain unauthorized access.

Impact:

Manual review and disabling requires administrative effort and careful validation to avoid mistakenly removing accounts that are still needed. A process to re-enable accounts upon business justification should be defined to limit disruption.

Audit:

1. Generate user activity reports for Fusion Applications or OCI Identity Domains.
2. Identify accounts with no sign-in activity for at least 90 days.
3. Identify accounts without assigned roles, groups, or owners.
4. Confirm that such accounts are reviewed and, if appropriate, disabled or removed.

Remediation:

1. Establish a policy defining thresholds for dormant accounts (for example, 90 days inactivity).
2. Schedule quarterly reports of user activity and ownership.
3. Review results with application owners.
4. Disable or delete dormant and orphaned accounts once confirmed unnecessary.
5. Document results and keep evidence for audit purposes.

Default Value:

By default, Fusion Applications and OCI Identity Domains do not enforce reviews or disabling of dormant accounts.

References:

1. <https://docs.oracle.com/en/cloud/saas/human-resources/ochus/manage-hcm-user-accounts.html>
2. <https://docs.oracle.com/en-us/iaas/Content/identity/domains/managing.htm>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 <u>Disable Dormant Accounts</u> Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			

2 Networking

This section contains recommendations for configuring network security related options. These controls help protect applications and data by restricting unauthorized connections, securing communication channels, and reducing exposure to network-based threats.

2.1 Ensure Network Perimeters are Configured in IAM or the Identity Provider (Manual)

Profile Applicability:

- Level 2

Description:

Network Perimeters restrict where users can sign in to Oracle SaaS applications by enforcing trusted IP ranges or network sources. For upgraded environments, this is configured natively in Oracle Identity Domains. For environments that have not yet been upgraded, equivalent controls should be configured in the external identity provider (IdP).

Rationale:

Restricting access to approved IPs or network locations at the identity layer reduces the risk of compromised credentials being used from untrusted or malicious networks. By placing the enforcement at the authentication layer, even valid credentials cannot be misused outside authorized locations.

Impact:

Configuring network perimeters may block legitimate users from signing in if they connect from locations or IP ranges not included in the allow-list, such as when traveling or working remotely, so organizations must keep ranges current and provide secure remote access options to balance security with usability.

Audit:

1. For upgraded environments:
 - Sign in to the Oracle Cloud Console.
 - Navigate to **Identity & Security, Domains, Security, Network Perimeters**.
 - Verify that at least one Network Perimeter is defined with authorized IP ranges and attached to sign-on policies.
2. For non-upgraded environments:
 - Review conditional access or equivalent policies in the IdP.
 - Confirm that rules are applied to restrict authentication attempts to approved IP ranges or network locations.

Remediation:

1. Upgraded environments (OCI IAM):

- Go to **Identity & Security, Domains, Security, Network Perimeters**.
- Create a perimeter with approved IP ranges.
- Attach the perimeter to sign-on policies.

2. Non-upgraded environments (external IdP):

- Configure conditional access rules in the IdP (Azure AD, Okta, etc.).
- Define approved IP ranges or geolocation-based conditions.
- Apply these rules to authentication policies used by Oracle SaaS.

Default Value:

No Network Perimeters are configured by default.

References:

1. <https://docs.oracle.com/en-us/iaas/Content/Identity/networkperimeters/overview.htm>
2. <https://docs.oracle.com/en-us/iaas/Content/fusion-applications/identity-migration-overview.htm>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	12.3 Securely Manage Network Infrastructure Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.			

2.2 Ensure OCI Console Access Is Restricted to Trusted Networks (Manual)

Profile Applicability:

- Level 1

Description:

Ensure that access to the Oracle Cloud Infrastructure (OCI) Console is restricted to trusted networks (secure VPNs or private network endpoints) by configuring IAM Network Sources

Rationale:

The OCI Console provides administrative access. If user credentials are compromised, unrestricted access from any IP address increases the attack surface. Restricting console login to approved IP ranges or VCN subnets enforces defense in depth and reduces the likelihood of unauthorized access.

Impact:

Restricting access may prevent legitimate users outside trusted networks from logging in. Organizations must maintain a secure break-glass account and carefully test network rules before enforcing them.

Audit:

1. Navigate to **Identity & Security, Domains, Security, Sign-On Policies**.
 - Confirm that console login rules reference a defined network source (for example, `request.networkSource.name = <TrustedSource>`).
 - Verify that there is no policy rule permitting console access from any network.
2. Navigate to **Identity & Security, Network Sources**.
 - Confirm that the trusted network source contains only approved IP addresses, CIDR blocks, or VCN subnets.

Remediation:

1. Define a Network Source with trusted IP ranges or VCN subnets:
 - Navigate to **Identity & Security, Network Sources, Create Network Source**.
 - Add approved IPs or CIDRs.
2. Update the Sign-On Policy for the identity domain:

- Add a rule that allows console login only if `request.networkSource.name` matches the trusted network source.
 - Add a default deny rule for all other networks.
3. Test access from both inside and outside the trusted network.
 4. Maintain a secure break-glass account exempt from the restriction.

Default Value:

Public access allowed by default unless restricted by Network Configurations manually.

References:

1. <https://docs.oracle.com/en/learn/access-to-oci-console/index.html>
2. <https://docs.oracle.com/en-us/iaas/Content/Identity/Tasks/managingnetworksources.htm>
3. MOS Note - Network Connectivity Patterns for Oracle Fusion Cloud Applications (Doc ID 3060221.1)
4. Restrict public access of Fusion Cloud Applications Blog Series - <https://www.ateam-oracle.com/post/part-1-restrict-public-access-of-fusion-cloud-applications-and-enable-access-to-oci-resources-using-vcn-customer-onprem-network>

Additional Information:

By default, OCI Console access is permitted from any network location. There is no restriction applied unless administrators explicitly configure network sources and sign-on policies.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v8	12.3 Securely Manage Network Infrastructure Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.			

2.3 Ensure Access to Fusion is restricted via Access Control List (ACL) (Manual)

Profile Applicability:

- Level 1

Description:

An Access Control List (ACL) restricts connections to Oracle Fusion SaaS environments by allowing access only from defined public IP addresses, CIDR ranges, or Oracle Cloud Infrastructure (OCI) Virtual Cloud Networks (VCNs). This ensures that access is limited to approved enterprise networks and private connectivity options such as FastConnect or VPN, while blocking all other traffic by default.

Rationale:

Enabling ACLs enforces strict network perimeter controls around Oracle Fusion environments. By limiting access to trusted IPs or VCNs, ACLs protect against unauthorized access attempts from the public internet and reduce the risk of brute force, credential stuffing, and other network-based attacks. ACLs also align with zero-trust principles by ensuring SaaS applications are not broadly exposed.

Impact:

Restricting Fusion access through ACLs may block legitimate users or integrations if required IP addresses or VCNs are not properly registered. This can cause downtime for business processes until the ACL is updated.

Audit:

1. Sign in to the Oracle Cloud Infrastructure Console with the appropriate administrator privileges
2. Navigate to the Fusion SaaS environment's network settings and locate the Access Control List configuration
3. Verify that ACLs are enabled for the environment
4. Confirm that the ACL contains only trusted public IP addresses, CIDR ranges, or OCI Virtual Cloud Networks (VCNs)
5. Check that the allowlist excludes overly broad ranges such as 0.0.0.0/0
6. Validate that exceptions are documented and limited to approved use cases (for example, supplier portal or integrations that must be accessible from external networks)
7. Attempt access from an unlisted IP or VCN to confirm that connections are blocked

Remediation:

1. In the Oracle Cloud Infrastructure Console, access the Fusion SaaS environment's network configuration
2. Enable the Access Control List feature if not already active
3. Add the organization's trusted public IP addresses, CIDR ranges, and/or OCI Virtual Cloud Networks (VCNs) to the ACL
4. Save the configuration and confirm that the ACL is enforced
5. Remove any broad or unnecessary ranges that could allow access from untrusted sources
6. Document any exceptions that must remain open, including justification and approval
7. Validate the changes by testing access from both allowed and disallowed networks to ensure enforcement is functioning as expected

Default Value:

No ACLs are enabled by default.

References:

1. <https://docs.oracle.com/en-us/iaas/Content/fusion-applications/network-setup.htm>
2. <https://blogs.oracle.com/cloud-infrastructure/post/expand-fusion-cloud-security-ipbased-filtering-1>

Additional Information:

This recommendation is specific to Oracle Fusion Cloud Applications.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	12.3 Securely Manage Network Infrastructure Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.			

2.4 Ensure Location-Based Access Control (LBAC) is enabled (Manual)

Profile Applicability:

- Level 1

Description:

Location-Based Access Control (LBAC) restricts user access to Oracle Fusion SaaS products based on network location. It applies to both user interface (UI) and API sign-ins. Access is allowed only from registered IP ranges, such as corporate offices or VPN gateways. Users connecting from unregistered networks receive only generic or limited access unless explicitly permitted.

Rationale:

Enabling LBAC enforces a perimeter-based restriction on where users and integrations can connect from. This complements authentication and role-based authorization by ensuring that even valid credentials cannot be used from untrusted or malicious networks. Implementing LBAC reduces the attack surface and aligns with the principle of least privilege.

Impact:

Enabling LBAC may prevent users from accessing Oracle Fusion Applications if they connect from networks not included in the allowlist, such as home offices, mobile connections, or partner sites. Administrators must carefully manage IP entries to avoid service disruption.

Audit:

1. Confirm that the IT Security Manager role is assigned
2. In a test or non-production environment, validate LBAC configuration before enabling in production
3. Navigate to **Navigator**, **Tools**, **Security Console**, **Location Based Access**
4. Verify that **Enable Location Based Access** is selected
5. Review the IP Address **Allowlist** to ensure it contains valid IPv4 or CIDR ranges for trusted networks
6. Confirm that the IT Security Manager role is designated as public to preserve administrative access
7. If LBAC is disabled, check that allowlist entries are retained in read-only mode for later use
8. Test login from a disallowed IP to confirm access is restricted, and from an allowed IP to confirm access works

Remediation:

1. Use an account with the IT Security Manager role to configure LBAC
2. In the Security Console, open the Location Based Access tab and select **Enable Location Based Access**
3. Add trusted IP addresses or CIDR ranges, including the administrator's current IP to avoid lockout
4. Save the configuration and confirm the change
5. Mark the IT Security Manager role as public to preserve console access even from unregistered networks
6. If disabling LBAC, deselect the option; allowlist entries remain stored for reuse
7. Validate by testing login from both trusted and untrusted IPs

Default Value:

LBAC is disabled by default.

References:

1. <https://docs.oracle.com/en/cloud/saas/human-resources/ochus/overview-of-location-based-access.html>
2. <https://docs.oracle.com/en-us/iaas/Content/fusion-applications/network-setup.htm>

Additional Information:

This recommendation is specific to Oracle Fusion Cloud Applications.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	12.3 Securely Manage Network Infrastructure Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.			

2.5 Ensure Geolocation Filtering with WAF for SaaS is enforced (Manual)

Profile Applicability:

- Level 2

Description:

Geolocation filtering in WAF for Oracle Fusion Applications restricts access based on the source country or region of incoming requests. WAF policies can be configured to allow or block traffic from selected geographies, helping organizations limit access to regions where legitimate users are located. This control must be enabled and validated through a Service Request with Oracle SaaS Operations.

Rationale:

Restricting access to only the countries or regions where the organization operates reduces unnecessary exposure to malicious traffic. Many automated attacks originate from outside business-relevant regions, and filtering them at the WAF layer prevents unwanted traffic from reaching the application.

Impact:

Enabling geolocation filtering may prevent legitimate users from connecting if they travel or work outside of approved regions. Organizations must balance security restrictions with user mobility and ensure that business-critical access is not unintentionally blocked.

Audit:

1. Review Service Request (SR) records with Oracle SaaS Operations to confirm that geolocation filtering has been enabled.
2. Verify the countries or regions included in the allow or block lists match organizational requirements.
3. Optionally log a new Service Request with Oracle SaaS Operations to confirm the current WAF policy configuration.
4. Validate functionality by attempting access from at least one blocked country and confirming that requests are denied.

Remediation:

1. Submit a Service Request to Oracle SaaS Operations requesting geolocation filtering to be enabled for the Fusion environment.
2. Provide Oracle with the list of countries or regions that should be allowed or blocked.
3. After configuration by Oracle, confirm that the rules are applied and enforced.

4. Test by accessing Fusion from both allowed and blocked regions to ensure expected behavior.
5. Document exceptions if broader access must remain temporarily enabled.

Default Value:

Geolocation filtering is disabled by default in WAF for SaaS.

References:

1. <https://blogs.oracle.com/cloud-infrastructure/post/expand-fusion-cloud-security-ipbased-filtering-2>
2. <https://community.oracle.com/customerconnect/discussion/673419/web-application-firewall-waf-for-fusion-applications-a-managed-service-from-saas-security>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 <u>Implement and Manage a Firewall on Servers</u> Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	12.3 <u>Securely Manage Network Infrastructure</u> Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.			

2.6 Ensure IP-Based Filtering with WAF for SaaS is Enforced (Manual)

Profile Applicability:

- Level 2

Description:

IP-based filtering in WAF for Oracle Fusion Applications restricts access to trusted public IP addresses or CIDR ranges. WAF rules can allow or block specific IP ranges so that only authorized enterprise networks (such as corporate offices, VPN gateways, or partner networks) can reach Fusion Applications. This control must be enabled and validated through a Service Request with Oracle SaaS Operations.

Rationale:

Restricting access by IP address or CIDR reduces the exposure of Fusion Applications to unauthorized traffic from the public internet. By ensuring only trusted network sources can connect, IP-based filtering helps protect against brute force attempts, scanning, and other malicious activity.

Impact:

Enabling IP-based filtering may inadvertently block legitimate users or integrations if their IP addresses are not registered in the allowlist. This requires ongoing maintenance of IP entries, especially for users with dynamic addresses or business partners with changing network ranges.

Audit:

1. Review Service Request (SR) records with Oracle SaaS Operations to confirm that IP-based filtering has been enabled.
2. Verify that the allowlist includes only approved public IP addresses or CIDR ranges corresponding to trusted networks.
3. Ensure no overly broad ranges, such as 0.0.0.0/0, are permitted.
4. Optionally log a Service Request with Oracle SaaS Operations to confirm the current WAF policy configuration.
5. Test connectivity from both an allowed and a disallowed IP address to confirm enforcement.

Remediation:

1. Submit a Service Request to Oracle SaaS Operations requesting IP-based filtering to be enabled for the Fusion environment.
2. Provide Oracle with a list of approved IP addresses or CIDR ranges representing trusted enterprise or VPN networks.
3. Review and approve Oracle's implementation of the filtering policy.

4. Remove any unnecessary or overly broad ranges.
5. Validate enforcement by testing API and UI access from both allowed and disallowed IP addresses.
6. Document exceptions if temporary external access is required.

Default Value:

IP-based filtering is disabled by default in WAF for SaaS.

References:

1. <https://blogs.oracle.com/cloud-infrastructure/post/expand-fusion-cloud-security-ipbased-filtering-2>
2. <https://community.oracle.com/customerconnect/discussion/673419/web-application-firewall-waf-for-fusion-applications-a-managed-service-from-saas-security>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	12.3 Securely Manage Network Infrastructure Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.			

2.7 Ensure Qualified Target Filtering with WAF for SaaS is Enforced (Manual)

Profile Applicability:

- Level 2

Description:

Qualified Target Filtering in WAF for Oracle Fusion Applications enables differentiated access control at the module or endpoint level. This allows organizations to apply stricter policies for sensitive internal modules while permitting broader access to externally facing modules, such as Supplier Portal and Oracle Recruiting Cloud Candidate Experience (ORC). Filtering rules can be defined per qualified target to separate external user traffic (e.g., suppliers, applicants) from internal corporate traffic. This control must be enabled and validated through a Service Request with Oracle SaaS Operations.

Rationale:

Not all Fusion modules require the same level of exposure. Internal corporate modules should be tightly restricted, while external-facing portals must allow controlled access for third parties. Qualified Target Filtering provides the flexibility to enforce strong network restrictions for corporate use while preserving access for suppliers and applicants, minimizing unnecessary risk while supporting business functions.

Impact:

Enabling Qualified Target Filtering introduces configuration complexity. If policies are misconfigured, legitimate external users (e.g., suppliers or job applicants) or internal users may be blocked from accessing required modules. Organizations must carefully maintain allowlists and country policies to prevent business disruption.

Audit:

1. Review Service Request (SR) records with Oracle SaaS Operations to confirm that Qualified Target Filtering has been enabled.
2. Verify which Fusion modules are included in the configuration (e.g., Supplier Portal, Candidate Experience).
3. Review allowlist/blocklist rules applied to each qualified target (CIDR ranges, countries, or both).
4. Optionally log a Service Request with Oracle SaaS Operations to confirm the current Qualified Target Filtering policies.
5. Validate by testing access to each configured module from both allowed and disallowed IPs or regions to ensure differentiated enforcement.

Remediation:

1. Submit a Service Request to Oracle SaaS Operations requesting Qualified Target Filtering to be enabled for the Fusion environment.
2. Provide Oracle with the list of Fusion modules requiring differentiated access (e.g., Supplier Portal, Candidate Experience) and their corresponding IP or geolocation restrictions.
3. Review Oracle's implementation to ensure policies match business and security requirements.
4. Test access for both corporate and external traffic (supplier, applicant) to confirm correct behavior.
5. Document exceptions where broader access must be maintained.

Default Value:

Qualified Target Filtering is disabled by default. Supplier Portal and Candidate Experience require explicit enablement by Oracle through a Service Request.

References:

1. <https://blogs.oracle.com/cloud-infrastructure/post/waf-saas-supports-fusion-supplier-portal-security>
2. <https://blogs.oracle.com/cloud-infrastructure/post/job-applicant-corporate-traffic-fusion-cloud-waf>
3. <https://blogs.oracle.com/cloud-infrastructure/post/expand-fusion-cloud-security-ipbased-filtering-2>
4. <https://community.oracle.com/customerconnect/discussion/673419/web-application-firewall-waf-for-fusion-applications-a-managed-service-from-saas-security>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	12.3 Securely Manage Network Infrastructure Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.			

3 Logging and Monitoring

This section contains recommendations for configuring logging and monitoring related options. These controls ensure that security events are recorded, monitored, and analyzed to support incident detection, response, and compliance requirements.

3.1 Ensure Fusion Applications Login, Logout and Session Events are Captured, Exported, and Forwarded to Central Logging (Manual)

Profile Applicability:

- Level 2

Description:

Capture all user authentication lifecycle events (successful and failed logins, logouts, session creation/termination, token refresh, and session invalidation) from Fusion Applications and ensure these events are exported to OCI Audit/Logging and forwarded to your centralized SIEM or log repository for retention, correlation, and alerting.

Sample alerts/detection rules:

- Multiple failed logins from same account or IP within short window.
- Login from new Geo-location or anonymized IP.
- Successful login immediately after password reset / privilege change.
- Concurrent sessions from geographically dispersed IPs for same user.

Rationale:

Authentication lifecycle events are fundamental telemetry for detecting account compromise, brute-force attacks, anomalous logins (time/location), and unauthorized session reuse. Centralizing these events enables correlation with other security data (privilege changes, API activity) and supports incident detection and forensic investigations.

Impact:

Enabling detailed session auditing increases log volume and storage/ingestion costs. Minimal performance impact on Fusion, integration work required to establish exports/pipelines and SIEM parsers.

Audit:

In the OCI Console

1. Verify Audit records (OCI Audit) capture high-level tenancy and console events. For Fusion application session details, verify the tenant's Fusion Audit export pipeline is configured, Confirm Fusion's audit export is sending events to OCI Logging or to Object Storage.
2. In OCI Logging (or Object Storage), search for recent Fusion session events (examples: **SignInSuccess**, **SignInFailure**, **SignOut**, **SessionCreated**). Use query filters for **eventName**, **principal**, **sourceIp**, and **eventTime**.

3. Confirm the Service Connector Hub ingestion pipeline (Logging → Service Connector Hub, Streaming, or Object Storage ingestion) is operational and logs are flowing.

Remediation:

1. Configure export Export audit events to OCI Logging (or to Object Storage + Streaming). If using Oracle's documented methods (REST API / Audit export), configure the export schedule and confirm delivery. 2. Establish ingestion pipeline: Create or verify the Service Connector Hub (OCI Logging → Streaming → SIEM) or object-storage-based ingestion.

Default Value:

By default, Fusion records authentication events in its internal audit store; however, export/forwarding to OCI Logging or SIEM is not guaranteed by default and typically requires configuration. Retention and immutability are tenant-specific and must be configured by the customer/integration.

References:

1. <https://www.ateam-oracle.com/post/methods-and-ways-to-extract-session-information-using-oci-audit-and-integrate-into-external-systems>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			

3.2 Ensure EPM Audit Data is Exported and Centrally Stored (Manual)

Profile Applicability:

- Level 2

Description:

EPM Cloud Applications generate audit data that records user sign-ins, administrative actions, and configuration changes. This audit data should be exported regularly from the EPM environment to ensure it is retained outside of the application. To ensure audit integrity and long-term availability, these audit records should be periodically exported from the service and stored in a centralized repository for example on Object Storage.

Rationale:

Audit data retained only inside EPM is limited by default retention policies and is vulnerable to loss or deletion. Exporting ensures durability and independence, while forwarding into OCI Logging Analytics or a SIEM enables consolidated monitoring, alerting, and compliance reporting across enterprise systems.

Impact:

Enabling regular export of EPM audit data introduces operational overhead for scheduling, storage, and monitoring of the export process. Not exporting audit data increases the risk of losing historical records once retention limits are reached, which may hinder forensic investigations, weaken compliance posture, and reduce visibility into unauthorized activities.

Audit:

1. Confirm that EPM audit data exports are scheduled and active.
2. Verify that audit data files contain expected details, such as user ID, login time, IP address, and executed functions.
3. Check that exported data is securely stored in an external location, like Object Storage.

Remediation:

- Configure automated export of EPM audit data (for example, with EPM Automate Access Log downloads).
- Store exported files securely outside the transactional environment.
- Test and validate that exports and any forwarding pipelines complete successfully, without data loss.

Default Value:

By default, audit data remains within the EPM environment, subject to internal retention limits. Export and any forwarding to external systems must be explicitly configured.

References:

1. https://docs.oracle.com/en/cloud/saas/enterprise-performance-management-common/cgsad/integration_with_custom_siem_tools.html
2. https://docs.oracle.com/en/cloud/saas/enterprise-performance-management-common/cepma/sample_script_8_download_files.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v8	8.9 <u>Centralize Audit Logs</u> Centralize, to the extent possible, audit log collection and retention across enterprise assets.			

3.3 Ensure to enable Audit on BI Publisher and OTBI Activity (Execution, Modification, and Usage Analytics) (Manual)

Profile Applicability:

- Level 2

Description:

Enable auditing and monitoring of all BI Publisher (BIP) and Oracle Transactional Business Intelligence (OTBI) reporting activity within Oracle Fusion Applications. This includes audit of report executions, catalog object creations, deletions, updates, and access control changes, as well as performance and concurrency usage metrics. Centralize this audit data for anomaly detection, insider-threat monitoring, and compliance reporting.

Rationale:

Reports and dashboards in Fusion Applications can access or export large volumes of sensitive operational and financial data. Auditing report execution and modification provides visibility into who viewed, changed, or extracted information, helping to prevent unauthorized disclosure or manipulation of analytics.

Usage metrics also provide early indicators of abuse or unusual access patterns.

Impact:

Enabling detailed BI/OTBI auditing increases log volume and may slightly impact BI performance. Requires careful selection of retention and export policies to manage storage.

Audit:

1. Check Audit In BI Publisher For Fusion SaaS Cloud Customers? (Doc ID 2059102.1) – KB61120
 - Login BI with an BI Administrator user
 - Navigate to: **Administration -> Manage BI Publisher -> Runtime Configuration -> Properties -> Data Model**
 - Ensure **Enable SQL session trace** is set to **True**
2. How to Track Delete, Archive and Unarchive Events in BI (KB86271)
 - Go to **Navigator**
 - Under Tools select **Audit Reports**
 - Enter the
 - Date After
 - User

- Product = Oracle Business Intelligence Enterprise Edition
 - Event Type (Optional)
- Click on **Search**
- Following are the list of **Event Type: BI Analysis Accessed, BI Dashboard Accessed, BI Catalog Object Created, BI Catalog Object Deleted, BI Catalog Object Updated, BI Catalog Object ACL Set**
- 3. Check if OTBI Usage & Performance Auditing is enabled: (Doc ID 2731495.1) - KB5355

Starting with Fusion Applications Release 20D

- 4. Verify data is in a SIEM, Centralized Logging Store, or OCI Logging Analytics.

Remediation:

1. How To Configure And Use Audit In BI Publisher For Fusion SaaS Cloud Customers? (Doc ID 2059102.1) – KB61120
 - Login BI with an BI Administrator user
 - Navigate to: **Administration -> Manage BI Publisher -> Runtime Configuration -> Properties -> Data Model**
 - If the following parameter is set to **True: Enable SQL session trace = True**
2. How to Track Delete , Archive and Unarchive Events in BI (KB86271)
 - Go to **Navigator**
 - Under Tools select **Audit Reports**
 - Enter the
 - Date After
 - User
 - Product = Oracle Business Intelligence Enterprise Edition
 - Event Type (Optional)
 - Click on **Search**
 - Following are the list of "Event Type": **BI Analysis Accessed, BI Dashboard Accessed, BI Catalog Object Created, BI Catalog Object Deleted, BI Catalog Object Updated, BI Catalog Object ACL Set**
3. Enable OTBI Usage & Performance Auditing (Doc ID 2731495.1) - KB5355

Starting with Fusion Applications Release 20D, two new subject areas are provided to monitor OTBI usage and performance:

- OTBI Usage Real Time: Monitors OTBI usage, including user, analysis and dashboard, and subject area usage trends.

- OTBI Performance Real Time: Monitors usage trends and OTBI analysis execution time, execution errors, and database physical SQL execution statistics.
- Captures OTBI Query execution data including ad-hoc queries, saved analyses and dashboards
- Six months of OTBI execution data is available in 20D.
- Data older than six months is purged weekly.
- Subject areas are secured by duty roles.
- Does not contain BI Catalog change audit data.

4. Centralize and Monitor

- Export BI and OTBI audit data to a SIEM, Centralized Logging Store, or OCI Logging Analytics.

Default Value:

By default, BI and OTBI auditing are partially disabled; customers must manually enable audit event tracking and export settings. Usage and performance data are not logged until explicitly activated.

References:

1. Oracle Doc ID 2059102.1 – How to Configure and Use Audit in BI Publisher for Fusion SaaS
2. Oracle Doc ID 2930706.1 – How to Track Delete, Archive, and Unarchive Events in BI
3. Oracle Doc ID 2731495.1 – How to Configure and Use Audit for Usage and Performance in OTBI
4. Methods to extract audit & monitoring data from Fusion cloud applications for SIEM Integrations <https://www.ateam-oracle.com/post/methods-to-extract-audit-monitoring-data-from-fusion-applications>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.14 Log Sensitive Data Access Log sensitive data access, including modification and disposal.			●
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●

3.4 Ensure BPM Approval Rule and Workflow Configuration Changes Are Audited (Manual)

Profile Applicability:

- Level 2

Description:

Enable and monitor auditing for changes to BPM (Business Process Management) approval rules and SOA workflow configurations within Oracle Fusion Applications. These rules determine the routing and approval hierarchy for critical business transactions (e.g., expense approvals, journal entries, purchase orders, HR changes). By auditing changes, organizations can maintain accountability for modifications that may alter segregation of duties or bypass established approval hierarchies.

Rationale:

Approval rules define key authorization paths that enforce financial and operational controls. Unauthorized or untracked changes can enable fraudulent approvals, insider threats, or policy violations. Auditing BPM/SOA configuration changes ensures the integrity and traceability of the enterprise approval model.

Impact:

Minimal performance impact. Enabling BPM audit logging may marginally increase database storage and administrative review workload.

Audit:

1. Access **Setup and Maintenance** → **Manage Audit Policies** → **Audit Configuration**.
2. Confirm that Audit for SOA/BPM Changes is Enabled (refer to Doc ID 2053746.1). Review Fusion Applications SOA Audit (Doc ID 2053746.1)
3. Verify that audit data is available through Audit Report / REST API.
4. Check for regular export or forwarding of BPM audit logs to the central logging system (OCI Logging / SIEM) for retention and correlation.
5. Review samples of recent approval rule modifications and confirm they match authorized change requests.

Remediation:

1. Enable auditing for SOA/BPM components in Fusion's audit configuration as per Doc ID 2053746.1.
2. Ensure all BPM rule changes are routed through change management or governance workflow.
3. Configure scheduled extraction of BPM audit logs for integration with centralized audit monitoring (OCI Logging, SIEM, or Analytics).

4. Implement periodic review (monthly/quarterly) of approval rule changes by business process owners and security administrators.
5. Set up alerts or dashboards for critical workflow-change events.

Default Value:

Auditing of BPM approval-rule changes is disabled by default and must be manually enabled via the Audit Policies configuration.

References:

1. Oracle Doc ID 2053746.1: How do administrators audit changes to SOA (Service Oriented Architecture) such as approval rules in Fusion Applications?
2. Methods to extract audit & monitoring data from Fusion cloud applications for SIEM Integrations <https://www.ateam-oracle.com/post/methods-to-extract-audit-monitoring-data-from-fusion-applications>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8 <u>Audit Log Management</u> Collect, alert, review, and retain audit logs of events that could help detect, understand, or recover from an attack.			
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			

3.5 Ensure Logging Pipelines are Monitored for Failures to Prevent Silent Loss of Audit Events (Manual)

Profile Applicability:

- Level 2

Description:

Audit and monitoring data from Oracle SaaS Applications is often exported and ingested into downstream systems such as Centralized Log Management (CLM) or Security Information and Event Management (SIEM) Platforms. If the export or ingestion pipelines fail, audit data may silently stop flowing, leaving security teams unaware of missing records. Monitoring and alerting should be enabled on all logging pipelines to detect failures and disruptions in log collection or forwarding.

In Oracle SaaS Connector Hub is the recommended log routing services. Organizations leveraging multi-cloud or hybrid environments may also use third-party log forwarding and observability agents to ensure reliable audit data delivery.

Rationale:

Audit data is critical for detecting malicious activity, ensuring accountability, and meeting compliance requirements. Pipeline failures can result in gaps that prevent accurate forensic investigations and weaken monitoring effectiveness. By actively monitoring the health of logging pipelines, organizations can ensure continuous visibility into user and administrative activity.

Impact:

Additional configuration and monitoring effort is required to track pipeline health. Alerts must be tuned to avoid noise, and storage costs may increase if diagnostic logs are retained for extended periods. However, the impact of silent audit data loss is far greater, as it can leave incidents undetected.

Audit:

1. If using OCI Service Connector Hub, open the OCI Console, review OCI Service Connector Hub to confirm monitoring is enabled on log collection and forwarding pipelines.
2. Check whether alarms exist in OCI Monitoring for connector errors, ingestion failures, or delivery delays.
3. Validate that alerts are directed to responsible administrators via email, pager, or incident management systems.
4. Inspect recent alarm history to confirm that test failures are detected and reported.

Remediation:

1. Configure OCI Monitoring alarms on Service Connector Hub pipelines to trigger when ingestion or forwarding fails.
2. Establish alert rules in Centralized Log Management (CLM) or SIEM Platform to detect periods with no incoming audit events.
3. Route alarms to administrators via Notifications, email, or ticketing systems.
4. Test the monitoring setup by intentionally pausing or misconfiguring a pipeline and verifying that alerts are generated.
5. Document the monitoring and escalation process in the organization's operational runbooks.

Default Value:

By default, Fusion Applications and OCI Audit logs are collected, but health monitoring of logging pipelines is not enforced. Organizations must configure monitoring and alerting explicitly.

References:

1. <https://www.ateam-oracle.com/post/methods-to-extract-audit-monitoring-data-from-fusion-applications>
2. <https://docs.oracle.com/en-us/iaas/Content/service-connector-hub/overview.htm>
3. <https://docs.oracle.com/en-us/iaas/Content/Monitoring/Tasks/usingalarms.htm>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v8	8.9 <u>Centralize Audit Logs</u> Centralize, to the extent possible, audit log collection and retention across enterprise assets.			

4 Application Configuration Management

This section contains recommendations for how your environment is configured. These controls help ensure that applications are deployed and maintained securely, with consistent baseline settings that reduce the risk of misconfigurations and support compliance requirements.

4.1 Security Configuration Changes

This section contains recommendations for managing security configuration changes. These controls ensure that changes are documented, authorized, monitored, and tested to prevent misconfigurations, reduce risk, and maintain a secure and consistent environment.

4.1.1 Ensure Changes to Audit Policy Settings Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that changes to Audit Policies are appropriate. Audit Policies record the changes made to Fusion Application configuration settings, which in turn determine the applications' behaviors. Each Audit Policy records changes to specific settings. Administrators enable each Audit Policy separately. Once an Audit Policy is enabled, audit information is stored without any intervention of the user or any explicit user action. Administrators can also disable any Audit Policy separately - i.e., specify that specific settings' changes will no longer be recorded - and re-enable them later.

Rationale:

Changes to Audit Policies impact the ability to detect changes to Fusion Application configurations, and consequent changes to the applications' behaviors. This control ensures that changes are recorded, reviewed, and if necessary, reversed.

If an Audit Policy is disabled erroneously, the ability to monitor changes to Fusion Application configurations is lost; those changes will alter the applications' behaviors without appropriate oversight.

If an Audit Policy is disabled maliciously, Fusion Application configurations can be changed in unauthorized ways - a potential exploit is to disable an Audit Policy, change an application configuration setting, abuse the changed behavior of the application, then restore the original configuration setting and re-enable the Audit Policy.

Impact:

Changes to Audit Policies are always recorded.

If changes and their consequences are not reviewed, the responsibility for being aware of the changes' consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Ensure that Audit Policies are enabled - and remain enabled - for Fusion Application configuration settings that have material impact on finances, operations, and compliance:

- Manual method: Review the Audit History report for Audit Policies:
 1. Navigate to **Tools, Audit Reports**.

2. Set Product to **Audit Policies**.
 3. Set Date to desired day/range.
 4. Tap **Search**.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor Audit Policy changes and initiate investigation workflows when unwanted changes occur.
 1. For example, deploy the control **60019: Track When Audit Policy is Disabled** using the instructions in [Continuously Monitor Configuration Changes](#).

Remediation:

1. Re-enable the Audit Policy.
 1. Navigate to **My Enterprise, Setup and Maintenance, Manage Audit Policies**
 2. Tap **Configure Business Object Attributes** in the Oracle Fusion Applications section.
 3. Re-enable the policy.
2. Review activity that occurred while the Audit Policy was disabled:
 - Manual method: Review the transactions that could be created or approved while the Audit Policy was disabled.
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs.
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The recording of changes to Audit Policies is always permanently enabled - i.e., it cannot be disabled.

References:

1. <https://docs.oracle.com/en/cloud/saas/applications-common/25c/facia/audit-policies.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			

4.1.2 Ensure Configuration Changes to HCM Security Profile Setups Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that changes to HCM security profiles are appropriate. Each profile gives users access to specific kinds of HCM data, like specific People or specific Payroll records. Each user can be assigned one or more profiles.

Rationale:

Each change to a profile has immediate effect for all users who have the profile.

If a profile is changed erroneously or maliciously, users will gain or lose access unexpectedly. In the case of a gain, users could see sensitive data without authorization.

Impact:

If changes and their consequences are not reviewed, the responsibility for being aware of the changes' consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

1. Enable audit of security profile changes using the instructions in [Configure Data Roles and Security Profiles for Audit](#)
2. Monitor changes to...
 1. That Audit Policy using the instructions in [Ensure Changes to Audit Policy Settings are Monitored](#).
 2. Security profiles:
 - Manual method: Review the Audit History report for profiles:
 1. Navigate to [Tools, Audit Reports](#).
 2. Set Product.
 3. Set Date to desired day/range.
 4. Tap [Search](#).
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor profile changes and initiate investigation workflows when unwanted changes occur.
 1. For example, deploy the following controls using the instructions in [Continuously Monitor Configuration Changes](#):

60008: Additions and Deletions to Data Roles, 60009: Updates to Data Roles, 60010: Additions and Deletions to Profile Options, 60011: Updates to Profile Options, 60015: Additions and Deletions to Security Profiles, and 60016: Updates to Security Profiles.

Remediation:

If audit has been disabled or was never enabled, see the instructions in [Ensure Changes to Audit Policy Settings are Monitored](#).

If unwanted changes were made to a profile:

1. Restore the profile's intended settings.
2. Review activity that occurred while those changes were in effect:
 - Manual method: Review the transactions that could be created or approved while the changes were in effect:
 1. Navigate to [Tools, Reports and Analytics](#).
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The recording of changes to profiles is not enabled by default - i.e., it must be enabled.

References:

1. <https://docs.oracle.com/en/cloud/saas/human-resources/fagbs/security-profiles.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			

4.1.3 Ensure Unused Custom Roles Are Disabled or Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that unused Custom Roles are disabled, or if they cannot or should not be disabled, that the actions they allow are monitored.

Rationale:

An unused custom role could be discovered by a user, assigned to a user (perhaps themselves or someone else) either erroneously or maliciously; then the beneficiary of the assignment could perform unintended or unauthorized actions.

Impact:

If persistence of unused Custom Roles is allowed, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Identify custom roles that are not assigned to any users.

- Manual method: Inspect each role's user assignments in Security Console.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor roles' assignments and initiate investigation workflows when they remain unassigned.
 1. For example, deploy the control **80001: Custom Roles Not Used** using the instructions in [Continuously Monitor Configuration Changes](#).

Remediation:

If a role that was previously unassigned is now discovered to be assigned to a user:

1. Either:
 - Make the role inactive.
 - Leave the role active and monitor the transactions performed if the role is assigned to a user (see below).
2. Review the user's actions since then:
 - Manual method: Review the transactions that the role allows:
 1. Navigate to **Tools Reports and Analytics**.

2. Select the appropriate dashboards or reports.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

References:

1. <https://docs.oracle.com/en/cloud/saas/human-resources/faqas/what-s-the-security-console.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 <u>Disable Dormant Accounts</u> Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

4.2 High Risk Business Transactions & User Actions

This section contains recommendations for monitoring and controlling high risk business transactions and user actions. These controls help protect sensitive processes, detect anomalous or fraudulent activity, and ensure that critical operations are performed securely and with proper oversight.

4.2.1 Ensure Changes to Payment Setups Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that Payment configuration changes are monitored.

Rationale:

Each change to a Payment configuration has immediate effect for all subsequent payments. Configurations include payment methods and bank account details.

If a configuration is changed erroneously or maliciously, payments could be directed to the wrong recipient. Once payments are made, they could be difficult to reclaim.

Impact:

If changes and their consequences are not reviewed, the responsibility for being aware of the changes' consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

1. Enable audit of Payment setup changes:
 1. Navigate to **My Enterprise, Setup and Maintenance, Manage Audit Policies**
 2. Tap **Configure Business Object Attributes** in the Oracle Fusion Applications section.
 3. Enable the Audit Policies for Payment setup attributes.
2. Monitor changes to...
 1. Those Audit Policies, using the instructions in **Ensure Changes to Audit Policy Settings are Monitored**.
 2. The Payment setups:
 - Manual method: Review the Audit History reports for the setups:
 1. Navigate to **Tools, Audit Reports**.
 2. Set Product.
 3. Set Date to desired day/range.
 4. Tap **Search**.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor Payment setup changes and initiate investigation workflows when unwanted changes occur.

1. For example, deploy the following controls using the instructions in [Continuously Monitor Configuration Changes](#): 60002: Frequent Changes to Supplier Bank Account Details, 60005: Frequent Changes to Supplier Payment Methods, and 60007: Changes to Supplier Bank Accounts on a Weekend.

Remediation:

If audit has been disabled or was never enabled, see the instructions in [Ensure Changes to Audit Policy Settings are Monitored](#).

If unwanted changes were made to a Payment setup:

1. Restore the intended settings.
2. Review activity that occurred while those changes were in effect:
 - Manual method: Review the transactions that could be created or approved while the changes were in effect:
 1. Navigate to [Tools, Reports and Analytics](#).
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of Payment setups is not enabled by default - i.e., it must be enabled.

References:

1. <https://docs.oracle.com/en/cloud/saas/financials/25d/facsf/how-you-implement-payables-and-payments.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●

4.2.2 Ensure Unused Business Setups Are Disabled (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that unused business setups are disabled, or if they cannot or should not be disabled, that the actions they allow are monitored. Business setups could include ledgers, suppliers, and customers, to name only a few.

Rationale:

An unused setup could be discovered by a user, then used either erroneously or maliciously. For example, journal entries could be made to unused ledgers, with subsequent impact on financial reporting accuracy; purchase orders, invoices and payments could be attributed to unused suppliers, resulting in lost cash; and goods or services could be attributed to unused customers, resulting in losses.

Impact:

If persistence of unused Business Setups is allowed, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Identify business setups that are not associated with transactions.

- Manual method:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor setup use and initiate investigation workflows when they remain unused:
 1. For example, deploy the following controls using the instructions in [Continuously Monitor Configuration Changes](#): **30009: Suppliers With No Invoice Activity**, **32003: Ledgers With No Journal Activity**, and **33004: Customers With No Invoice Activity**.

Remediation:

If a business setup that was previously unused is now discovered to have been used,

1. Either:

- Make the setup inactive.
 - Leave the setup active and monitor the transactions performed if the setup is used in transactions (see below).
2. Review those transactions:
- Manual method: Review the transactions that include the setup:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of business setups is not enabled by default - i.e., it must be enabled.

References:

1. <https://docs.oracle.com/en/cloud/saas/financials/25d/facsf/implement-general-ledger.html>
2. <https://docs.oracle.com/en/cloud/saas/supply-chain-and-manufacturing/25d/faicf/create-a-supplier-and-supplier-site.html>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 <u>Disable Dormant Accounts</u> Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

4.3 Ensure Configuration Changes to Roles Built for IT Superusers Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that pervasive or substantial abilities to configure and change Fusion are monitored.

Rationale:

Those abilities let users fundamentally change the behavior of the applications. Erroneous or malicious changes could have substantial impact on operations and finances.

Impact:

If changes and their consequences are not reviewed, the responsibility for being aware of the changes' consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Identify users who have been assigned an IT superuser role - e.g., **Application Implementation Consultant**.

- Manual method: Inspect the role's assignments in Security Console.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor the role's assignments and initiate investigation workflows when those assignments change.
 1. For example, deploy the control **60024: New Users Assigned to Application Implementation Consultant Role** using the instructions in [Continuously Monitor Configuration Changes](#).

Remediation:

When a user is assigned to the role:

1. Either:
 - Remove unwanted assignments.
 - Leave assignments and monitor the transactions performed by assigned users (see below).
2. Review the user's actions since then:
 - Manual method: Review the transactions that the role allows:
 1. Navigate to **Tools, Reports and Analytics**.

2. Select the appropriate dashboards or reports.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			

4.4 Ensure Uploaded Files Are Scanned for Viruses and Restricted by Extension Policy (Manual)

Profile Applicability:

- Level 1

Description:

In Oracle EPM Cloud, you can enable pre-upload virus scanning using the `setVirusScanOnFileUploads` command so that files with malware are blocked before upload. In addition, enforce a file extension policy to restrict potentially dangerous file types (executables, scripts) from being uploaded.

Rationale:

Automatically scanning files before upload prevents malicious content from entering the environment. Combined with extension restrictions, this defense-in-depth approach reduces the risk from malware, ransomware, or embedded scripts being introduced via file upload.

Impact:

Enabling scanning may slow upload processes slightly, and extension restrictions may block business-required files that are uncommon. An exception approval process may be needed.

Audit:

1. Run `epmautomate getVirusScanOnFileUploads` to check whether scanning is enabled. If it returns `false`, scanning is not enforced. `[OBJ]`
2. Confirm that the file upload behavior prevents known malicious signatures (e.g. test with EICAR file) or rejects infected files.
3. Review documentation or environment settings that disallow certain binary file types (e.g. .exe, .bat, .msi, .vbs) as indicated in the `uploadFile` command spec.
4. Ensure that only Service Administrators have permission to run `setVirusScanOnFileUploads`.
5. Verify that any exceptions to the extension allow/deny policy are documented and reviewed.

Remediation:

- Use `epmautomate setVirusScanOnFileUploads true` to enable virus scanning before files are uploaded. `[OBJ]`
- If needed, define or refine a policy of allowed and disallowed extension types to block risky formats.
- Test uploads to validate scanning and blocking is working as expected.

- Ensure that role assignment is controlled so only trusted Service Administrators can modify scan settings.
- Document exception handling (for business-justified file types) and apply compensating controls.

Default Value:

By default, file upload virus scanning is disabled (false).

References:

1. https://docs.oracle.com/en/cloud/saas/enterprise-performance-management-common/cepma/epm_auto_set_virus_scan_onfile_uploads.html
2. https://docs.oracle.com/en/cloud/saas/enterprise-performance-management-common/cepma/epm_auto_upload_file.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			

5 Application Access Control

This section contains recommendations for how access is granted and managed within applications. Use processes and tools to create, assign, manage, and revoke access credentials and privileges for user, administrator, and service accounts to ensure secure and appropriate access to enterprise assets and software.

5.1 IT Administrator Seperation of Duties (SoD)

Monitor IT Admin Superuser Access & Transactions

5.1.1 Ensure Transactions Created/Updated by Fusion Administrators Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that creation, update and approval of transactions by administrators are monitored.

Rationale:

Erroneous or malicious transactions could have substantial impact on operations, finances and legal/regulatory compliance.

Impact:

If transactions are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

- Manual method: Review the transactions:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:

1. Deploy the following controls using the instructions in [Continuously Monitor Transactions](#): 41001: Approved Payable Invoices by IT Superusers, 41002: Created or Updated Payable Invoices by IT Superusers, 41003: Created or Updated Payments by IT Superusers, 41004: Created or Updated Suppliers by IT Superusers, 41005: Approval Workflow Rules for Financials by IT Superusers, 41006: Approved or Posted Journals by IT Superusers, 41007: Created or Updated Journals by IT Superusers, 41008: Created or Updated General Ledger Account Combinations by IT Superusers, 41009: Created or Updated General Ledger Options by IT Superusers, 41010: Created or Updated Customers by IT Superusers, 41011: Created or Updated Receivables Invoices by IT Superusers, 41012: Created or Updated Receivables Standard Receipts by IT Superusers, 42001: Created or Updated Employee Job Assignments by IT Superusers, 42002: Created or Updated Employee Payroll Transactions by IT Superusers, 42003: Created or Updated Employee Personal Payment Methods by IT Superusers, and 42004: Created or Updated Employee Salary by IT Superusers.

Remediation:

1. Reverse the transaction if possible.
2. Identify the configurations that allowed the transaction and alter them if possible - for details see the preceding recommendations.

Default Value:

The monitoring of transactions is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.2 Establish and Maintain a Secure Configuration Process for Network Infrastructure</u> Establish and maintain a secure configuration process for network devices. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.			

5.1.2 Ensure Assignments of Substantial Access to Fusion Users Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that assignments of pervasive or substantial abilities to configure and change Fusion, create/approve transactions, and view sensitive data are monitored.

Rationale:

Those abilities give users freedom to fundamentally change the behavior of the applications, create/approve transactions, and view sensitive data without the usual separation of duties (SoD) or oversight. Erroneous or malicious actions could have substantial impact on operations, finances, and legal/regulatory compliance.

Impact:

If users are allowed to retain those abilities, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Identify users who have been assigned privileges that let them change the behavior of the applications, create/approve transactions, and view sensitive data.

- Manual method: Review assignments - e.g., HDL logs.
- Automated method: Create Access Controls in Fusion Cloud Applications Risk Management that continuously monitor the roles' assignments and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Automate Separation of Duties Reporting for Compliance](#): 4085: HDL Import Data into Stage Tables & HDL Import Data into Application Tables, 4096: HDL Sensitive Data Loader Privilege, 4097: HDL Sensitive Data Exchange Work Area, and 9361: Sensitive IT Security Privileges.

Remediation:

When a user is assigned the privileges:

1. Either:

- Remove unwanted assignments.
- Leave assignments and monitor the transactions performed by assigned users (see below).
- 2. Review the user's actions since then:
 - Manual method: Review the transactions that the privileges allow:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.2 Establish and Maintain a Secure Configuration Process for Network Infrastructure</u> Establish and maintain a secure configuration process for network devices. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.			

5.1.3 Ensure Assignments of Substantial Access to EPM Administrators Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that pervasive or substantial abilities to view sensitive data are monitored - for example, data about accounts and financial data.

Rationale:

Those abilities give users freedom to view sensitive data without the usual oversight. Erroneous or malicious actions could have substantial impact on operations, finances, and legal/regulatory compliance.

Impact:

If users are allowed to retain those abilities, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

EPM performance is not impacted.

Audit:

Identify users who have been assigned privileges that let them view sensitive data.

- Manual method: In EPM, identify roles that contain privileges that let users view sensitive data. Then inspect each role's user assignments.
- Automated method: Create Access Controls in Fusion Cloud Applications Risk Management that continuously monitor the roles' assignments and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Automate Separation of Duties Reporting for Compliance: 4608: Sensitive EPM Accounts Reconciliation \(ARCS\) Superuser roles](#) and [4616: Sensitive EPM Financial Consolidation \(FCCS\) Superuser roles](#).

Remediation:

When a user is assigned to one of the privileges:

- Remove unwanted assignments.
- Ensure that the user complies with all data handling policies.

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.2 Establish and Maintain a Secure Configuration Process for Network Infrastructure</u> Establish and maintain a secure configuration process for network devices. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.			

5.2 Application Superuser Seperation of Duties (SoD)

Monitor Business Superusers Access & Transactions

5.2.1 Ensure Assignments of Substantial Access to Business Users Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that pervasive or substantial abilities to view sensitive data are monitored - for example, data about employees or their pay, suppliers, customers, or bank accounts.

Rationale:

Those abilities give users freedom to view sensitive data without the usual oversight. Erroneous or malicious actions could have substantial impact on operations, finances, and legal/regulatory compliance.

Impact:

If users are allowed to retain those abilities, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Identify users who have been assigned privileges that let them view sensitive data.

- Manual method: In Security Console, identify roles that contain privileges that let users view sensitive data. Then inspect each role's user assignments.
- Automated method: Create Access Controls in Fusion Cloud Applications Risk Management that continuously monitor the roles' assignments and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Automate Separation of Duties Reporting for Compliance: 4079](#): Sensitive Human Resource Privileges, 4080: Sensitive Payroll Privileges, 6681: Sensitive Set Up Procurement Privileges, 9800: Sensitive Customer Privileges, 9801: Sensitive Supplier Privileges, 9802: Sensitive Payment Privileges, 9804: Sensitive Purchasing Privilege, and 9805: HR Sensitive Access Analysis for Excluded Role.

Remediation:

When a user is assigned to one of the privileges:

- Remove unwanted assignments.
- Ensure that the user complies with all data handling policies.

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.3 Application Business User Seperation of Duties (SoD)

Monitor for Separation of Duties in Access

5.3.1 Ensure SoD Within Fusion Is Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that the ability to perform an unwanted combination of actions within Fusion is monitored.

Rationale:

Erroneous or malicious actions could have substantial impact on operations, finances and legal/regulatory compliance.

Impact:

If users are allowed to retain those abilities, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application and OCI performance are not impacted.

Audit:

Identify users who have been assigned combinations of Fusion privileges that let them perform unwanted actions.

- Manual method: In Security Console, identify users that have those combinations.
- Automated method: Create Access Controls in Fusion Cloud Applications Risk Management that continuously monitor the privileges' assignments and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Automate Separation of Duties Reporting for Compliance](#): 4051: Manage Employee and Manage Payroll, 4052: Manage Time and Labor and Manage Payroll, 4053: Manage Employee and Manage Compensation, 4054: Manage Employee and Manage Payroll Batch Processes, 4055: Manage Employee and Manage Payroll Costing, 4056: Manage Worker and Manage Payroll, 4057: Manage Worker and Manage Payroll Batch Processes, 4058: Manage Worker and Manage Payroll Costing, 4059: Manage Person and Manage Payroll, 4060: Manage Person and Manage Payroll Batch Processes, 4061: Manage Person and Manage Payroll Costing, 4062: Create User and Manage Payroll, 4063: Create User and Manage Payroll Batch Processes, 4064: Create User and Manage Payroll Costing, 4068: Manage Time and Labor and Manage Payroll Batch Processes, 4069: Manage Time and Labor and

Manage Payroll Costing, 4070: Manage Worker and Manage Compensation, 4071: Manage Person and Manage Compensation, 4073: Manage Employee Position and Manage Compensation, 5800: Approve Payables Invoices and Create Payables Invoices, 5810: Approve Payables Invoices and Create Payments, 5892: Maintain Supplier Bank Accounts and Create Payments, 5980: Create Suppliers and Create Payments, 6080: Create Purchase Orders and Define Procurement Approval Routing Rules, 6390: Create Suppliers and Create Payables Invoices, and 6410: Create Suppliers and Create Purchase Orders.

Remediation:

When a user is assigned the privileges:

1. Either:
 - Remove unwanted assignments.
 - Leave assignments and monitor the transactions performed by assigned users (see below).
2. Review the user's actions since then:
 - Manual method: Review the transactions that the privileges allow:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.3.2 Ensure SoD Across Fusion and EPM Is Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that the ability to perform an unwanted combination of actions in Fusion and EPM is monitored.

Rationale:

Erroneous or malicious actions could have substantial impact on finances and legal/regulatory compliance.

Impact:

If users are allowed to retain those abilities, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application and EPM performance are not impacted.

Audit:

1. Identify users who have been assigned combinations of Fusion and EPM privileges that let them perform unwanted actions.
 - Manual method: In Fusion and EPM's user access administration tools, identify users that have those combinations.
 - Automated method: Create Access Controls in Fusion Cloud Applications Risk Management that continuously monitor the privileges' assignments and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Automate Separation of Duties Reporting for Compliance](#): 4601: EPM Accounts Reconciliation (ARCS) Superuser and Fusion Create Payables Invoices, 4602: EPM Accounts Reconciliation (ARCS) Superuser and Fusion Create Payments, 4603: EPM Accounts Reconciliation (ARCS) Superuser and Fusion Create Purchase Orders, 4604: EPM Accounts Reconciliation (ARCS) Superuser and Fusion Enter Customer Receipts, 4605: EPM Accounts Reconciliation (ARCS) Superuser and Fusion Enter Journals, 4606: EPM Accounts Reconciliation (ARCS) Superuser and Fusion Inventory Transactions, 4607: EPM Accounts Reconciliation (ARCS) Superuser and Fusion Physical Inventory, 4609: EPM Financial Consolidation (FCCS) Superuser and Fusion Create Payables Invoices,

4610: EPM Financial Consolidation (FCCS) Superuser and Fusion Create Payments, 4611: EPM Financial Consolidation (FCCS) Superuser and Fusion Create Purchase Orders, 4612: EPM Financial Consolidation (FCCS) Superuser and Fusion Enter Customer Receipts, 4613: EPM Financial Consolidation (FCCS) Superuser and Fusion Enter Journals, 4614: EPM Financial Consolidation (FCCS) Superuser and Fusion Inventory Transactions, and 4615: EPM Financial Consolidation (FCCS) Superuser and Fusion Physical Inventory.

Remediation:

When a user is assigned the privileges:

1. Either:
 - Remove unwanted assignments.
 - Leave assignments and monitor the transactions performed by assigned users (see below).
2. Review the user's actions since then:
 - Manual method: Review the transactions that the privileges allow:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

5.3.3 Ensure SoD Across Fusion and OCI Is Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that the ability to perform an unwanted combination of actions in Fusion and its OCI environment is monitored.

Rationale:

Erroneous or malicious actions could have substantial impact on operations, finances and legal/regulatory compliance.

Impact:

If users are allowed to retain those abilities, and the consequences are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application and OCI performance are not impacted.

Audit:

1. Identify users who have been assigned combinations of Fusion and OCI privileges that let them perform unwanted actions.
 - Manual method: In Fusion and OCI's user access administration tools, identify users that have those combinations.
 - Automated method: Create Access Controls in Fusion Cloud Applications Risk Management that continuously monitor the privileges' assignments and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Automate Separation of Duties Reporting for Compliance](#): 4651: OCI DBaaS Administrator and Fusion BI Administrator, 4652: OCI SOA Administrator and Fusion Workflow Administrator, 4653: OCI Service Administrator and Fusion Security Administrator, and 4654: OCI Service Developer and Fusion Security Administrator.

Remediation:

When a user is assigned the privileges:

1. Either:
 - Remove unwanted assignments.
 - Leave assignments and monitor the transactions performed by assigned users (see below).

2. Review the user's actions since then:
 - Manual method: Review the transactions that the privileges allow:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
 - Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of role assignments is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

5.3.4 Ensure Fusion ERP Transactions Allowed by SoD Violations Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that ERP transactions that violate separation of duties policies (SoD) are monitored.

Rationale:

Erroneous or malicious transactions could have substantial impact on operations, finances and legal/regulatory compliance.

Impact:

If transactions are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

- Manual method: Review the transactions:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the following controls using the instructions in [Continuously Monitor Transactions](#): **40001: Supplier and Payables Invoices Created by the Same User**, **40004: Payment Process Request Created by Same User Managing Suppliers**, **40005: Suppliers and Purchase Orders Managed by the Same User**, **40008: External Bank Accounts and Payments Managed by the Same User**, **40009: Purchase Orders and Procurement Approval Routing Rules Managed by the Same User**, **40012: Payable Invoices Approved and Created by the Same User**, **40013: Payable Invoices Approved and Payment Created by the Same User**, **40015: Requisition and Purchase Order Managed by the Same User**, **40017: Payments and Requisitions Managed by the Same User**.

Remediation:

1. Reverse the transaction if possible.
2. Identify the configurations that allowed the transaction and alter them if possible - for details see the preceding recommendations.

Default Value:

The monitoring of transactions is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

5.3.5 Ensure Fusion HCM Transactions Allowed by SoD Violations Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that HCM transactions that violate separation of duties policies (SoD) are monitored.

Rationale:

Erroneous or malicious transactions could have substantial impact on operations, finances and legal/regulatory compliance.

Impact:

If transactions are not reviewed, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

- Manual method: Review the transactions:
 1. Navigate to **Tools, Reports and Analytics**.
 2. Select the appropriate dashboards or reports.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the following controls using the instructions in [Continuously Monitor Transactions](#): **50001: Payroll Transactions and Personal Payment Method Managed by Same User**, **50002: Payroll Transactions and Time Cards Managed by Same User**, and **50005: Salary and Personal Payment Method Managed by Same User**.

Remediation:

1. Reverse the transaction if possible.
2. Identify the configurations that allowed the transaction and alter them if possible - for details see the preceding recommendations.

Default Value:

The monitoring of transactions is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

5.3.6 Ensure Shared EPM Accounts Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that sharing of EPM user accounts is monitored.

Rationale:

Sharing of accounts could have substantial impact on operations, finances and legal/regulatory compliance. For example, sharing makes it impossible to identify the person who performed an erroneous or malicious action.

Impact:

If a user account is allowed to be shared, the responsibility for being aware of the consequences must be accomplished through another means.

EPM performance is not impacted.

Audit:

Identify accounts that are used by more than one person.

- Manual method: In EPM, identify accounts.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor account use and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Continuously Monitor Transactions](#): **45001: Shared User Accounts in EPM Account Reconciliation** and **45002: Shared User Accounts in EPM Financial Consolidation and Close**.

Remediation:

When an account is shared:

1. Either:
 - Inactivate the account.
 - Change the account password and share the new password with only one user.
 - Allow sharing to continue and monitor the transactions performed by the users (see below).
2. Review actions since the account was shared.

Default Value:

The sharing of accounts is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.5 <u>Establish and Maintain an Inventory of Service Accounts</u> Establish and maintain an inventory of service accounts. The inventory, at a minimum, must contain department owner, review date, and purpose. Perform service account reviews to validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.			

5.3.7 Ensure Potential Ghost Employees Are Monitored (Manual)

Profile Applicability:

- Level 1

Description:

The purpose of this recommendation is to ensure that the ability of employees to be paid without working is monitored.

Rationale:

Employees who are paid without working could have substantial impact on operations, finances and legal/regulatory compliance.

Impact:

If employees are allowed to be paid without working, the responsibility for being aware of the consequences must be accomplished through another means.

Fusion Application performance is not impacted.

Audit:

Identify users who have been paid without working.

- Manual method: In HCM, identify users who have payroll entries without time entries or other evidence of work.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor suspicious hires and initiate investigation workflows when those assignments change.
 1. For example, deploy the following controls using the instructions in [Continuously Monitor Transactions](#): 50003: Employee New Hire Created by Same User Managing Personal Payments and 50004: Employee New Hire Created by Same User Managing Time Cards.

Remediation:

When a user is paid without working:

1. Either:
 - Terminate the user's employment.
 - Allow employment to continue and monitor the transactions performed by the user and their hiring managers (see below).
2. Review actions since then:
 - Manual method: Review the transactions performed by the user and their hiring managers:
 1. Navigate to **Tools, Reports and Analytics**.

2. Select the appropriate dashboards or reports.
- Automated method: Create Transaction Controls in Fusion Cloud Applications Risk Management that continuously monitor those transactions and initiate investigation workflows when unwanted activity occurs:
 1. Deploy the appropriate controls using the instructions in [Continuously Monitor Transactions](#).

Default Value:

The monitoring of employees is not enabled by default - i.e., it must be enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.5 <u>Establish and Maintain an Inventory of Service Accounts</u> Establish and maintain an inventory of service accounts. The inventory, at a minimum, must contain department owner, review date, and purpose. Perform service account reviews to validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.			

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	Identity and Access Management		
1.1	Ensure Password Policy Enforces Length and Rotation (Manual)	☐	☐
1.2	Ensure MFA is Enforced for All SaaS Users (Manual)	☐	☐
1.3	Ensure Phishing-Resistant MFA Is Enforced for SaaS Administrators and Privileged Accounts (Manual)	☐	☐
1.4	Ensure Fusion Applications Administrators Have Access Only to Fusion Applications Resources (Manual)	☐	☐
1.5	Ensure OCI Console Access Is Restricted to Administrative Accounts (Manual)	☐	☐
1.6	Ensure Privileged and Administrative Roles Are Restricted to Known IP Addresses (Manual)	☐	☐
1.7	Ensure Privileged Access is Certified Periodically (Manual)	☐	☐
1.8	Ensure Oracle Break Glass for Fusion Cloud Service Is Enabled (Manual)	☐	☐
1.9	Ensure Basic Authentication Is Blocked for SOAP and REST API Integrations (Manual)	☐	☐
1.10	Ensure All API Based Integrations Use OAuth Authentication (Manual)	☐	☐
1.11	Ensure Integration Account Secrets Are Rotated on a Regular Schedule (Manual)	☐	☐
1.12	Ensure EPM Automate Credentials Are Protected via Secure Storage (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.13	Ensure Dormant Accounts and Orphaned Identities Are Automatically Detected and Disabled (Manual)	☐	☐
1.14	Ensure Dormant Accounts and Orphaned Identities Are Reviewed and Disabled (Manual)	☐	☐
2	Networking		
2.1	Ensure Network Perimeters are Configured in IAM or the Identity Provider (Manual)	☐	☐
2.2	Ensure OCI Console Access Is Restricted to Trusted Networks (Manual)	☐	☐
2.3	Ensure Access to Fusion is restricted via Access Control List (ACL) (Manual)	☐	☐
2.4	Ensure Location-Based Access Control (LBAC) is enabled (Manual)	☐	☐
2.5	Ensure Geolocation Filtering with WAF for SaaS is enforced (Manual)	☐	☐
2.6	Ensure IP-Based Filtering with WAF for SaaS is Enforced (Manual)	☐	☐
2.7	Ensure Qualified Target Filtering with WAF for SaaS is Enforced (Manual)	☐	☐
3	Logging and Monitoring		
3.1	Ensure Fusion Applications Login, Logout and Session Events are Captured, Exported, and Forwarded to Central Logging (Manual)	☐	☐
3.2	Ensure EPM Audit Data is Exported and Centrally Stored (Manual)	☐	☐
3.3	Ensure to enable Audit on BI Publisher and OTBI Activity (Execution, Modification, and Usage Analytics) (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3.4	Ensure BPM Approval Rule and Workflow Configuration Changes Are Audited (Manual)	☐	☐
3.5	Ensure Logging Pipelines are Monitored for Failures to Prevent Silent Loss of Audit Events (Manual)	☐	☐
4	Application Configuration Management		
4.1	Security Configuration Changes		
4.1.1	Ensure Changes to Audit Policy Settings Are Monitored (Manual)	☐	☐
4.1.2	Ensure Configuration Changes to HCM Security Profile Setups Are Monitored (Manual)	☐	☐
4.1.3	Ensure Unused Custom Roles Are Disabled or Monitored (Manual)	☐	☐
4.2	High Risk Business Transactions & User Actions		
4.2.1	Ensure Changes to Payment Setups Are Monitored (Manual)	☐	☐
4.2.2	Ensure Unused Business Setups Are Disabled (Manual)	☐	☐
4.3	Ensure Configuration Changes to Roles Built for IT Superusers Are Monitored (Manual)	☐	☐
4.4	Ensure Uploaded Files Are Scanned for Viruses and Restricted by Extension Policy (Manual)	☐	☐
5	Application Access Control		
5.1	IT Administrator Separation of Duties (SoD)		
5.1.1	Ensure Transactions Created/Updated by Fusion Administrators Are Monitored (Manual)	☐	☐
5.1.2	Ensure Assignments of Substantial Access to Fusion Users Are Monitored (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.1.3	Ensure Assignments of Substantial Access to EPM Administrators Are Monitored (Manual)	☐	☐
5.2	Application Superuser Separation of Duties (SoD)		
5.2.1	Ensure Assignments of Substantial Access to Business Users Are Monitored (Manual)	☐	☐
5.3	Application Business User Separation of Duties (SoD)		
5.3.1	Ensure SoD Within Fusion Is Monitored (Manual)	☐	☐
5.3.2	Ensure SoD Across Fusion and EPM Is Monitored (Manual)	☐	☐
5.3.3	Ensure SoD Across Fusion and OCI Is Monitored (Manual)	☐	☐
5.3.4	Ensure Fusion ERP Transactions Allowed by SoD Violations Are Monitored (Manual)	☐	☐
5.3.5	Ensure Fusion HCM Transactions Allowed by SoD Violations Are Monitored (Manual)	☐	☐
5.3.6	Ensure Shared EPM Accounts Are Monitored (Manual)	☐	☐
5.3.7	Ensure Potential Ghost Employees Are Monitored (Manual)	☐	☐

Appendix: CIS Controls v8 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Ensure Password Policy Enforces Length and Rotation	☐	☐
1.2	Ensure MFA is Enforced for All SaaS Users	☐	☐
1.4	Ensure Fusion Applications Administrators Have Access Only to Fusion Applications Resources	☐	☐
1.5	Ensure OCI Console Access Is Restricted to Administrative Accounts	☐	☐
1.6	Ensure Privileged and Administrative Roles Are Restricted to Known IP Addresses	☐	☐
1.7	Ensure Privileged Access is Certified Periodically	☐	☐
1.8	Ensure Oracle Break Glass for Fusion Cloud Service Is Enabled	☐	☐
1.11	Ensure Integration Account Secrets Are Rotated on a Regular Schedule	☐	☐
1.13	Ensure Dormant Accounts and Orphaned Identities Are Automatically Detected and Disabled	☐	☐
1.14	Ensure Dormant Accounts and Orphaned Identities Are Reviewed and Disabled	☐	☐
2.1	Ensure Network Perimeters are Configured in IAM or the Identity Provider	☐	☐
2.2	Ensure OCI Console Access Is Restricted to Trusted Networks	☐	☐
2.3	Ensure Access to Fusion is restricted via Access Control List (ACL)	☐	☐
2.4	Ensure Location-Based Access Control (LBAC) is enabled	☐	☐
2.5	Ensure Geolocation Filtering with WAF for SaaS is enforced	☐	☐
2.6	Ensure IP-Based Filtering with WAF for SaaS is Enforced	☐	☐
2.7	Ensure Qualified Target Filtering with WAF for SaaS is Enforced	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.1	Ensure Fusion Applications Login, Logout and Session Events are Captured, Exported, and Forwarded to Central Logging	☐	☐
3.3	Ensure to enable Audit on BI Publisher and OTBI Activity (Execution, Modification, and Usage Analytics)	☐	☐
3.5	Ensure Logging Pipelines are Monitored for Failures to Prevent Silent Loss of Audit Events	☐	☐
4.1.3	Ensure Unused Custom Roles Are Disabled or Monitored	☐	☐
4.2.2	Ensure Unused Business Setups Are Disabled	☐	☐
4.4	Ensure Uploaded Files Are Scanned for Viruses and Restricted by Extension Policy	☐	☐
5.1.1	Ensure Transactions Created/Updated by Fusion Administrators Are Monitored	☐	☐
5.1.2	Ensure Assignments of Substantial Access to Fusion Users Are Monitored	☐	☐
5.1.3	Ensure Assignments of Substantial Access to EPM Administrators Are Monitored	☐	☐

Appendix: CIS Controls v8 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Ensure Password Policy Enforces Length and Rotation	☐	☐
1.2	Ensure MFA is Enforced for All SaaS Users	☐	☐
1.3	Ensure Phishing-Resistant MFA Is Enforced for SaaS Administrators and Privileged Accounts	☐	☐
1.4	Ensure Fusion Applications Administrators Have Access Only to Fusion Applications Resources	☐	☐
1.5	Ensure OCI Console Access Is Restricted to Administrative Accounts	☐	☐
1.6	Ensure Privileged and Administrative Roles Are Restricted to Known IP Addresses	☐	☐
1.7	Ensure Privileged Access is Certified Periodically	☐	☐
1.8	Ensure Oracle Break Glass for Fusion Cloud Service Is Enabled	☐	☐
1.9	Ensure Basic Authentication Is Blocked for SOAP and REST API Integrations	☐	☐
1.10	Ensure All API Based Integrations Use OAuth Authentication	☐	☐
1.11	Ensure Integration Account Secrets Are Rotated on a Regular Schedule	☐	☐
1.12	Ensure EPM Automate Credentials Are Protected via Secure Storage	☐	☐
1.13	Ensure Dormant Accounts and Orphaned Identities Are Automatically Detected and Disabled	☐	☐
1.14	Ensure Dormant Accounts and Orphaned Identities Are Reviewed and Disabled	☐	☐
2.1	Ensure Network Perimeters are Configured in IAM or the Identity Provider	☐	☐
2.2	Ensure OCI Console Access Is Restricted to Trusted Networks	☐	☐
2.3	Ensure Access to Fusion is restricted via Access Control List (ACL)	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.4	Ensure Location-Based Access Control (LBAC) is enabled	☐	☐
2.5	Ensure Geolocation Filtering with WAF for SaaS is enforced	☐	☐
2.6	Ensure IP-Based Filtering with WAF for SaaS is Enforced	☐	☐
2.7	Ensure Qualified Target Filtering with WAF for SaaS is Enforced	☐	☐
3.1	Ensure Fusion Applications Login, Logout and Session Events are Captured, Exported, and Forwarded to Central Logging	☐	☐
3.2	Ensure EPM Audit Data is Exported and Centrally Stored	☐	☐
3.3	Ensure to enable Audit on BI Publisher and OTBI Activity (Execution, Modification, and Usage Analytics)	☐	☐
3.4	Ensure BPM Approval Rule and Workflow Configuration Changes Are Audited	☐	☐
3.5	Ensure Logging Pipelines are Monitored for Failures to Prevent Silent Loss of Audit Events	☐	☐
4.1.1	Ensure Changes to Audit Policy Settings Are Monitored	☐	☐
4.1.2	Ensure Configuration Changes to HCM Security Profile Setups Are Monitored	☐	☐
4.1.3	Ensure Unused Custom Roles Are Disabled or Monitored	☐	☐
4.2.1	Ensure Changes to Payment Setups Are Monitored	☐	☐
4.2.2	Ensure Unused Business Setups Are Disabled	☐	☐
4.3	Ensure Configuration Changes to Roles Built for IT Superusers Are Monitored	☐	☐
4.4	Ensure Uploaded Files Are Scanned for Viruses and Restricted by Extension Policy	☐	☐
5.1.1	Ensure Transactions Created/Updated by Fusion Administrators Are Monitored	☐	☐
5.1.2	Ensure Assignments of Substantial Access to Fusion Users Are Monitored	☐	☐
5.1.3	Ensure Assignments of Substantial Access to EPM Administrators Are Monitored	☐	☐
5.3.6	Ensure Shared EPM Accounts Are Monitored	☐	☐
5.3.7	Ensure Potential Ghost Employees Are Monitored	☐	☐

Appendix: CIS Controls v8 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Ensure Password Policy Enforces Length and Rotation	☐	☐
1.2	Ensure MFA is Enforced for All SaaS Users	☐	☐
1.3	Ensure Phishing-Resistant MFA Is Enforced for SaaS Administrators and Privileged Accounts	☐	☐
1.4	Ensure Fusion Applications Administrators Have Access Only to Fusion Applications Resources	☐	☐
1.5	Ensure OCI Console Access Is Restricted to Administrative Accounts	☐	☐
1.6	Ensure Privileged and Administrative Roles Are Restricted to Known IP Addresses	☐	☐
1.7	Ensure Privileged Access is Certified Periodically	☐	☐
1.8	Ensure Oracle Break Glass for Fusion Cloud Service Is Enabled	☐	☐
1.9	Ensure Basic Authentication Is Blocked for SOAP and REST API Integrations	☐	☐
1.10	Ensure All API Based Integrations Use OAuth Authentication	☐	☐
1.11	Ensure Integration Account Secrets Are Rotated on a Regular Schedule	☐	☐
1.12	Ensure EPM Automate Credentials Are Protected via Secure Storage	☐	☐
1.13	Ensure Dormant Accounts and Orphaned Identities Are Automatically Detected and Disabled	☐	☐
1.14	Ensure Dormant Accounts and Orphaned Identities Are Reviewed and Disabled	☐	☐
2.1	Ensure Network Perimeters are Configured in IAM or the Identity Provider	☐	☐
2.2	Ensure OCI Console Access Is Restricted to Trusted Networks	☐	☐
2.3	Ensure Access to Fusion is restricted via Access Control List (ACL)	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.4	Ensure Location-Based Access Control (LBAC) is enabled	☐	☐
2.5	Ensure Geolocation Filtering with WAF for SaaS is enforced	☐	☐
2.6	Ensure IP-Based Filtering with WAF for SaaS is Enforced	☐	☐
2.7	Ensure Qualified Target Filtering with WAF for SaaS is Enforced	☐	☐
3.1	Ensure Fusion Applications Login, Logout and Session Events are Captured, Exported, and Forwarded to Central Logging	☐	☐
3.2	Ensure EPM Audit Data is Exported and Centrally Stored	☐	☐
3.3	Ensure to enable Audit on BI Publisher and OTBI Activity (Execution, Modification, and Usage Analytics)	☐	☐
3.4	Ensure BPM Approval Rule and Workflow Configuration Changes Are Audited	☐	☐
3.5	Ensure Logging Pipelines are Monitored for Failures to Prevent Silent Loss of Audit Events	☐	☐
4.1.1	Ensure Changes to Audit Policy Settings Are Monitored	☐	☐
4.1.2	Ensure Configuration Changes to HCM Security Profile Setups Are Monitored	☐	☐
4.1.3	Ensure Unused Custom Roles Are Disabled or Monitored	☐	☐
4.2.1	Ensure Changes to Payment Setups Are Monitored	☐	☐
4.2.2	Ensure Unused Business Setups Are Disabled	☐	☐
4.3	Ensure Configuration Changes to Roles Built for IT Superusers Are Monitored	☐	☐
4.4	Ensure Uploaded Files Are Scanned for Viruses and Restricted by Extension Policy	☐	☐
5.1.1	Ensure Transactions Created/Updated by Fusion Administrators Are Monitored	☐	☐
5.1.2	Ensure Assignments of Substantial Access to Fusion Users Are Monitored	☐	☐
5.1.3	Ensure Assignments of Substantial Access to EPM Administrators Are Monitored	☐	☐
5.2.1	Ensure Assignments of Substantial Access to Business Users Are Monitored	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.3.1	Ensure SoD Within Fusion Is Monitored	☐	☐
5.3.2	Ensure SoD Across Fusion and EPM Is Monitored	☐	☐
5.3.3	Ensure SoD Across Fusion and OCI Is Monitored	☐	☐
5.3.4	Ensure Fusion ERP Transactions Allowed by SoD Violations Are Monitored	☐	☐
5.3.5	Ensure Fusion HCM Transactions Allowed by SoD Violations Are Monitored	☐	☐
5.3.6	Ensure Shared EPM Accounts Are Monitored	☐	☐
5.3.7	Ensure Potential Ghost Employees Are Monitored	☐	☐

Appendix: CIS Controls v8 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
	No unmapped recommendations to CIS Controls v8	☐	☐

Appendix: Change History

Date	Version	Changes for this version
Nov 14, 2025	1.0.0	Document Created